DEPARTAMENTO DE ELECTROTECNIA E INFORMÁTICA
INGENIERÍA EN INFORMÁTICA

Diseño de un marco de ciberseguridad y protección de datos para el tratamiento seguro de identidades y registros de acceso vehicular en proyecto de gestión vehicular

S.I.G.T.E.

Ismael Abdón Galindo Acuña

igalindo@usm.cl

Ricardo Cahe

Profesor Guía

Resumen

-

Palabras clave

Ciberseguridad, Gestión vehicular, Gobernanza, Protección de datos, Tratamiento de datos personales

Agradecimientos

-

1. Introducción

La transformación digital ha modernizado el control del flujo vehicular en entornos comunitarios mediante plataformas como S.I.G.T.E. (Sistema Inteligente de Gestión del Tránsito y Estacionamiento), proyecto de la Universidad Técnica Federico Santa María (UTFSM), sede Viña del Mar. Diseñado para mitigar la congestión, la falta de trazabilidad y las ineficiencias logísticas, este sistema emplea validación multimodal (LPR, códigos QR y credenciales institucionales) combinada con aplicaciones web progresivas. No obstante, al centralizar y correlacionar patentes vehiculares, números de identificación civil (RUT), roles y marcas temporales georreferenciadas, la plataforma construye perfiles conductuales detallados de movilidad y permanencia, lo que introduce riesgos críticos de filtración, suplantación de identidad, manipulación de bitácoras y uso indebido de información personal.

Frente a este escenario y bajo el marco legal chileno (regido por la Ley N° 19.628, sustancialmente reformada por la Ley N° 21.719 sobre Protección de Datos Personales [que homologa los estándares del RGPD y crea la Agencia de Protección de Datos Personales]), el tratamiento de estos registros impone

estrictas responsabilidades éticas y normativas para la institución. En respuesta, esta tesina diseña, formaliza y evalúa un marco de ciberseguridad y gobernanza de la privacidad adaptado a la arquitectura distribuida de S.I.G.T.E. La propuesta integra los enfoques de Security by Design y Privacy by Design, sustentándose en estándares como ISO/IEC 27001, ISO/IEC 27701, NIST CSF y OWASP para estructurar controles técnicos y metodológicos que garanticen la resiliencia operativa y el debido cumplimiento normativo.

1.1 Contexto y definición del problema

1.1.1 Situación actual sin proyecto

El control de acceso perimetral y la fiscalización vehicular en la sede Viña del Mar de la UTFSM operan bajo un esquema estrictamente manual, analógico y reactivo, carente de integración entre los puntos de acceso físico y los sistemas centrales de información. La verificación en los 3 accesos de la sede depende de la memoria visual del personal de seguridad, cotejos contra listas impresas desactualizadas o cuadernos de bitácora en papel y planillas Excel locales dispares, además que no existe la posibilidad de conocer con exactitud el uso y aforo de los 4 estacionamientos de la sede. Esta dinámica genera cuatro problemas críticos:

- **Congestión y cuellos de botella en horas punta:** Latencias de verificación de 20 a 90 segundos por vehículo en portería, colapsando las vías públicas adyacentes a la sede.
- **«Tránsito ciego» y degradación del espacio físico:** Al no existir mecanismos de información de aforo en tiempo real, los conductores circulan de forma ociosa buscando estacionamiento, elevando el riesgo de colisiones menores, emisiones y bloqueos de vías de evacuación.
- **Pérdida de trazabilidad y desamparo probatorio:** La dispersión de anotaciones físicas y archivos aislados impide correlacionar entradas, salidas e infractores, anulando la capacidad de auditoría ante incidentes, robos o daños a la infraestructura.
- **Sobrecarga y desvío del rol de seguridad:** Los guardias absorben una carga administrativa desproporcionada en ventanilla, mermando su capacidad de vigilancia activa en el perímetro institucional.

1.1.2 Introducción al proyecto S.I.G.T.E.

Para erradicar las ineficiencias del esquema manual, surge el proyecto **S.I.G.T.E. (Sistema Inteligente de Gestión del Tránsito y Estacionamiento)**. La plataforma se concibe como una solución integral orientada a automatizar el acceso perimetral, dotar de visibilidad espacial en tiempo real a los conductores y centralizar la fiscalización institucional.

Objetivo general del proyecto

Desarrollar una plataforma digital integral (web y móvil) para la gestión vehicular del campus, que automatice el control de acceso y la administración de estacionamientos por bloques para mejorar la seguridad, el orden y la eficiencia operativa del personal de seguridad.

Objetivos específicos del proyecto

- **Implementar un control de acceso con validación multimodal:** Desarrollar e integrar mecanismos de autenticación mediante lectura automática de patentes (LPR), escaneo de códigos QR y credenciales universitarias digitales para automatizar el ingreso y salida de vehículos autorizados al campus.
- **Desarrollar un sistema de monitoreo de ocupación en tiempo real:** Diseñar una plataforma (web y móvil) que contabilice el flujo vehicular y muestre la disponibilidad de cupos por bloques de estacionamiento con indicadores visuales semafóricos.
- **Construir un módulo de fiscalización digital e infracciones:** Proporcionar al personal de seguridad herramientas móviles para registrar digitalmente faltas o incidencias internas, vinculándolas a la matrícula del vehículo y creando un historial auditable.
- **Centralizar la gestión de datos e identidades:** Implementar una base de datos única y segura que administre el registro de usuarios (conductores, guardias y administradores), vehículos autorizados, personas de confianza y la trazabilidad completa de los eventos de entrada y salida.
- **Asegurar la continuidad operacional mediante redundancia (Modo Respaldo):** Desarrollar un mecanismo alternativo de validación por código QR que permita continuar la operación del control de acceso ante fallas técnicas, climáticas o de iluminación en el sistema LPR.

Tabla 1. Matriz de problemas y soluciones propuestas por S.I.G.T.E.

Problema de la situación actual	Causa raíz técnica / operativa	Solución implementada en S.I.G.T.E.	Beneficio e impacto operativo
Cuellos de botella en accesos y demoras críticas.	Proceso manual dependiente de interacción humana y revisión de papeles.	Validación automatizada por reconocimiento de patentes (LPR), complementada con lectura de códigos QR efímeros y credenciales institucionales.	Reducción de más del 80% en los tiempos de verificación por vehículo en portería.
Tránsito ocioso y desorden en estacionamientos.	Inexistencia de mecanismos de información de aforo en tiempo real.	Módulo de monitoreo de ocupación por sectores/bloques con mapa semafórico (Verde / Amarillo / Rojo).	Eliminación del tránsito errático; el conductor conoce la disponibilidad antes de ingresar al recinto.
Impunidad ante faltas viales y pérdida de historial auditable.	Registros dispersos en planillas Excel y bitácoras de papel sin vinculación relacional.	Módulo de fiscalización digital móvil que vincula patentes con la hoja de vida institucional del conductor de forma centralizada.	Trazabilidad histórica completa, generación de reportes administrativos y fomento de la autorregulación comunitaria.
Carga administrativa excesiva sobre el personal de guardia.	Delegación del control de listas y anotación manual en las casetas.	Interfaz de guardia simplificada (focus mode) en PWA que arroja veredictos binarios automáticos	Dignificación de la función de seguridad, permitiendo que el guardia retome su rol de

		(Autorizado / Denegado).	vigilancia y gestión de contingencias.

Requisitos funcionales y no funcionales del sistema

- **Requerimientos Funcionales (RF):**
  - **RF-01 (Identificación LPR):** El sistema debe capturar ópticamente la placa patente del móvil en acceso y consultar la base de datos central para autorizar o rechazar el ingreso.
  - **RF-02 (Validación de contingencia):** El sistema debe permitir la autenticación de usuarios mediante lectura de código QR dinámico desde la PWA del conductor o mediante lectura de cédula/credencial.
  - **RF-03 (Contabilidad de aforo sectorizado):** El sistema debe actualizar en tiempo real el contador de vehículos de cada bloque o zona de estacionamiento.
  - **RF-04 (Registro de infracciones):** El sistema debe permitir al guardia capturar y registrar faltas al reglamento de tránsito asociándolas a la matrícula infractora.
  - **RF-05 (Reportería administrativa):** El sistema debe generar dashboards y reportes exportables sobre tasas de ocupación, horas de mayor demanda e historiales de sanciones.
- **Requerimientos No Funcionales (RNF):**
  - **RNF-01 (Latencia operativa):** El tiempo total entre la captura de una matrícula/código y el veredicto de apertura no debe superar los 2 segundos para evitar congestión en barrera.
  - **RNF-02 (Disponibilidad):** La plataforma debe garantizar alta disponibilidad durante los bloques horarios de mayor flujo vehicular de la sede.
  - **RNF-03 (Accesibilidad multiplataforma):** Las vistas operativas deben ejecutarse como Progressive Web Apps (PWA) sin requerir instalaciones nativas pesadas en los dispositivos móviles de guardias y usuarios.
  - **RNF-04 (Seguridad de la información):** Las comunicaciones y el almacenamiento de datos deben estructurarse bajo protocolos de integridad y confidencialidad.
  - **RNF-05 (Usabilidad en terreno):** La interfaz de los guardias debe priorizar la ergonomía visual (focus mode) con información condensada y de lectura inmediata.

Tabla 2. Matriz de alineación: Interesados y Requerimientos de S.I.G.T.E.

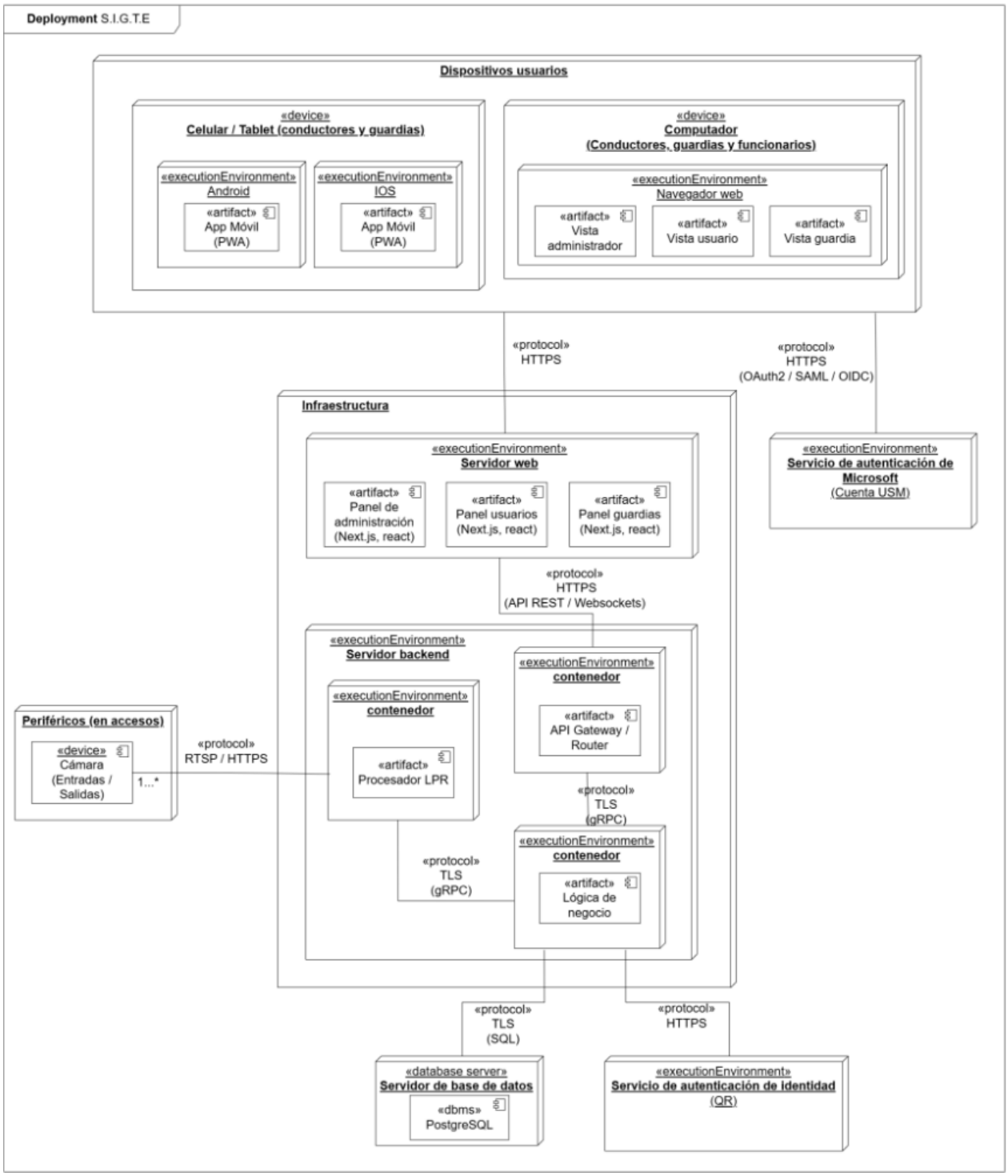
Interesado	Necesidad individual	Requerimiento asociado en S.I.G.T.E.	Impacto en la experiencia del usuario
Conductores	Ingreso sin esperas ni fricciones mecánicas.	RF-01 (LPR), RNF-01 (Baja latencia).	Acceso fluido en segundos; eliminación de detenciones innecesarias.
Conductores	Conocer disponibilidad antes del trayecto.	RF-03 (Ocupación), RNF-03 (PWA móvil).	Planificación eficiente; erradicación del "tránsito ciego" dentro de la sede.

Guardias	Herramienta rápida que elimine el papel.	RF-02 (Validación QR), RNF-05 (Focus mode).	Verificación ágil mediante celular; eliminación del error de cotejo visual.
Guardias	Respaldo probatorio ante sanciones.	RF-04 (Infracciones digitales).	Registro objetivo sin confrontaciones verbales con infractores.
Administración	Métricas consolidadas del uso de la sede.	RF-05 (Reportería y auditoría).	Toma de decisiones basada en datos para obras viales o sanciones.

1.1.3 Arquitectura del sistema de S.I.G.T.E.

Elementos principales de la arquitectura (Nivel conceptual)

Figura 1. Diagrama de despliegue de S.I.G.T.E.



La solución S.I.G.T.E. adopta una arquitectura cliente-servidor desacoplada en cuatro niveles principales:

- **Puntos de captura perimetral e IoT:** Nodos periféricos ubicados en las casetas encargados de la adquisición de señales del mundo físico (video, lectura de patentes y activación de actuadores/barreras).

- **Capa central de lógica y servicios (API Backend):** Núcleo centralizado que procesa las reglas de negocio, resuelve la autenticación, efectúa la conmutación de aforos y expone interfaces estandarizadas para los clientes.
- **Persistencia unificada de datos:** Repositorio central que resguarda el modelo relacional del sistema: identidades, perfiles de usuario, vínculos con patentes, registros cronológicos de tránsito y bitácoras de sanciones.
- **Interfaces de interacción y presentación (Frontend Web y PWA):** Vistas desacopladas y diseñadas según el rol operativo del usuario, orientadas al consumo ágil sobre redes públicas o institucionales.

Innovación propuesta por el proyecto

- **Validación vehicular multimodal:** La verificación pasa de una detención obligatoria con validación de identidad únicamente por escaneo QR de carnet o listas de papel para invitados a una validación automática por cámara LPR. El ingreso se autoriza de forma desatendida; la interacción con el guardia queda restringida a eventos de excepción (vehículo no enrolado, contingencia de lectura o visitas).
- **Comprobación de estacionamientos:** Se elimina el desplazamiento errático por el recinto. El conductor consulta su PWA antes de llegar y visualiza la disponibilidad exacta de cada bloque de estacionamientos (por ejemplo: "Estacionamiento 1: 12 cupos, Estacionamiento 2: Saturado"), dirigiéndose directamente al sector con plazas libres.
- **Fiscalización y auditoría:** Las multas y citaciones se cursan desde la interfaz del guardia mediante captura fotográfica directa. El evento impacta de inmediato en la base de datos centralizada, actualizando la hoja de vida del infractor y habilitando a los administradores para auditar reincidencias en tiempo real.

Tecnologías involucradas e integraciones

- **Frontend y Backend unificado (Next.js 14):** Framework que articula Server-Side Rendering (SSR) para paneles administrativos y generación estática/híbrida para las API Routes internas que actúan como backend REST. Desplegado en la plataforma serverless de **Vercel**.
- **Persistencia relacional (PostgreSQL en Neon):** Motor de base de datos PostgreSQL en modalidad serverless con escalabilidad bajo demanda, gestionado a nivel de código mediante el esquema tipado de **Prisma ORM**.
- **Visión computacional y captura LPR:** Cámaras IP con software integrado de reconocimiento óptico de patentes (OCR), comunicadas con el backend mediante peticiones web cifradas.
- **Control de acceso y sesiones (NextAuth.js):** Librería especializada en la emisión y validación de tokens de sesión y desacoplamiento de permisos de usuario.
- **Integración continua y automatización (GitHub Actions):** Orquestación del pipeline de integración y despliegue continuo (CI/CD) para la verificación de compilación y despliegue a producción.

1.1.4 Definición del problema

Si bien el diseño de S.I.G.T.E. resuelve las deficiencias logísticas de la sede, introduce una concentración masiva de información que traslada el riesgo institucional desde el plano físico hacia el plano digital. En

su estado de desarrollo preliminar, la plataforma carece de salvaguardas formales de ciberseguridad y gobernanza de la privacidad, lo que genera vulnerabilidades estructurales que motivan y justifican este trabajo.

A continuación se exploran los cuatro ejes principales de los problemas del sistema en su versión actual:

- **Vulnerabilidad de las credenciales de validación multimodal:** La ausencia de controles criptográficos avanzados en los tokens de acceso temporal (como códigos QR estáticos o credenciales digitales no ligadas criptográficamente a la identidad) facilita ataques de repetición (replay attacks), captura de credenciales por canal inseguro y suplantación física en el punto de acceso.
- **Exposición excesiva de datos personales y falta de minimización:** Las interfaces operativas (tanto de guardias en terreno como de administradores) carecen de políticas formales de segregación de roles (RBAC) y minimización de datos. El personal de guardia tiene acceso a información personal sensible que excede lo estrictamente necesario para la decisión de apertura de barrera vehicular.
- **Falta de inmutabilidad y no repudio en bitácoras:** Los eventos de acceso (ingreso/salida) y las sanciones cursadas carecen de mecanismos de sellado criptográfico o bitácoras blindadas contra manipulación (tamper-proof logs), lo que anula la validez forense de los registros ante reclamos administrativos o auditorías forenses.
- **Debilidades en la superficie de ataque de la arquitectura distribuida:** La exposición de endpoints de API REST, la comunicación entre terminales móviles y servicios de backend, y el almacenamiento persistente de identificadores vehiculares en bases de datos relacionales sin esquemas definidos de cifrado en reposo ni ciclos de vida de depuración (data pruning), incrementan el riesgo de exfiltración de información y ataques categorizados en el OWASP API Security Top 10.

Tabla 3. Matriz de brechas de seguridad y vectores de riesgo

Dimensión de vulnerabilidad	Estado preliminar de S.I.G.T.E.	Vectores de amenaza / Riesgos
Validación Multimodal	Códigos QR estáticos y credenciales digitales sin ligadura criptográfica.	• Ataques de repetición (replay attacks) mediante capturas de pantalla. • Clonación y suplantación física en el acceso.
Privacidad y Exposición de Datos	La interfaz de los guardias muestra datos completos del conductor (RUT, nombre, carrera) al escanear.	• Divulgación no autorizada de datos personales. • Perfilamiento y vigilancia desproporcionada.
Persistencia de Información	Registros de tránsito almacenados en texto claro en PostgreSQL sin seudonimización.	Filtración masiva de historiales de desplazamiento ante brechas en la base de datos.

Trazabilidad y Auditoría	Bitácoras de acceso y registro de infracciones almacenadas como registros editables convencionales.	Alteración maliciosa o repudio de multas e historiales por usuarios privilegiados (tampering).
Superficie de Ataque en APIs	Endpoints REST de Next.js expuestos sin limitación de tasa (rate limiting) estricta.	• Denegación de servicio (DoS) contra el acceso. • Autorización rota a nivel de objeto (BOLA).
Gobernanza del Ciclo de Vida	Almacenamiento indefinido de eventos históricos de acceso y georreferencia.	Generación de perfiles de permanencia históricos que violan el principio de finalidad.

1.2 Propuesta de solución y alcance

Atendiendo las brechas de seguridad y privacidad digitales antes mencionadas presentes en la arquitectura del sistema S.I.G.T.E. (donde convergen validaciones multimodales y la correlación centralizada de patentes, identificadores civiles y bitácoras que generan perfiles detallados de movilidad sin salvaguardas formales), se propone el diseño, formalización y evaluación de un marco integral de ciberseguridad y gobernanza de la privacidad, articulado bajo los paradigmas de Seguridad por Diseño (Security by Design) y Privacidad por Diseño (Privacy by Design - PbD).

La presente propuesta se fundamenta en estándares y marcos reconocidos en la industria, tales como ISO/IEC 27001, ISO/IEC 27701, NIST Cybersecurity Framework y OWASP, a la par de normativas legales chilenas que regulan la protección de datos personales y la implementación de medidas defensivas para prevenir incidentes digitales, entre las que destacan la Ley N° 21.719 (que reforma a la Ley N° 19.628 para convergencia con el RGPD), adaptando cada uno a las restricciones de latencia operativa y a la arquitectura distribuida del sistema. La solución propuesta se articula en torno a cinco núcleos técnicos interconectados:

1.2.1 Tratamiento seguro de identidades y validación criptográfica multimodal

Para neutralizar efectivamente la suplantación de identidad en porterías, la interceptación por canales inseguros y los ataques de repetición (replay attacks) inherentes al uso de credenciales estáticas, se formaliza un esquema criptográfico robusto de validación:

- **Tokens efímeros y firmados (HMAC/JWT):** Los códigos QR dinámicos y credenciales digitales temporales incorporan una firma digital criptográfica asociada a la identidad del usuario y una ventana de caducidad temporal estricta (TTL). Esto impide la clonación, reutilización fuera de horario y manipulación del contenido binario del QR y/o del token en tránsito.
- **Control de acceso basado en roles (RBAC):** Definición de matrices formales de privilegios para los tres perfiles operativos del sistema (conductores, personal de seguridad/guardias y personal administrativo), desacoplando los permisos de validación de identidad y control del tránsito de las facultades de administración y reportería.

1.2.2 Gobernanza y Privacidad por Diseño (Privacy by Design)

En estricta conformidad con la Ley N° 19.628 (y su actualización con la Ley N° 21.719 para converger con el estándar RGPD), la solución aborda la protección de los datos de carácter personal generados y registrados en cada interacción vehicular y peatonal:

- **Minimización de datos en interfaces de usuario:** Reestructuración de las vistas operativas de la aplicación progresiva (PWA) de los guardias en terreno. En lugar de exponer datos sensibles filtrables (RUT, fecha de nacimiento o nombres completos), la interfaz se restringe estrictamente a un indicador de validación operacionalmente suficiente (nombre y apellido, autorización binaria: ingreso autorizado / denegado).
- **Seudonimización en capas de persistencia y búsqueda ciega:** Sustitución de claves naturales por identificadores opacos (UUID v4) y cifrado autenticado de patentes en reposo (AES-256-GCM), integrando un índice ciego determinista mediante HMAC-SHA256 con sal secreta institucional para permitir búsquedas directas desde el procesador LPR sin descifrar masivamente registros.
- **Ciclo de vida y depuración (data pruning):** Formalización de directrices y procedimientos automatizados para la retención controlada y expurgación periódica de bitácoras históricas antiguas (3 años o más), impidiendo el almacenamiento indefinido de perfiles conductuales.

1.2.3 Endurecimiento (Hardening) de la arquitectura distribuida y comunicaciones

Para mitigar la superficie de ataque expuesta en los servicios backend, interfaces web y dispositivos móviles, se contempla:

- **Seguridad en tránsito y reposo:** Implementación obligatoria de canales cifrados de transporte de datos mediante TLS 1.3 / HTTPS / gRPC para toda comunicación entre dispositivos móviles y APIs, en conjunto con mecanismos de cifrado en reposo para el almacenamiento persistente en la base de datos.
- **Mitigación preventiva según OWASP API Security:** Protección de endpoints de la API frente a vulnerabilidades recurrentes (autorización rota a nivel de objeto, consumo irrestricto de recursos y autenticación débil).
- **Seguridad integrada en el pipeline CI/CD:** Incorporación de compuertas automatizadas de análisis estático de código (SAST) y análisis de dependencias vulnerables (SCA) dentro del ciclo de entrega continua.

1.2.4 Inmutabilidad, no repudio y trazabilidad forense

A fin de garantizar la validez probatoria legal de las operaciones de fiscalización y resolver disputas administrativas, se contempla:

- **Bitácoras a prueba de manipulación (tamper-proof logs):** Especificación de requerimientos técnicos concretos para el sellado criptográfico y encadenamiento de auditoría de los eventos de acceso vehicular (marcas temporales georreferenciadas, lecturas LPR y boletas de infracción cursadas).
- **No repudio:** Aseguramiento de que ninguna acción registrada por el personal de seguridad o los administradores pueda ser alterada, eliminada o desconocida con posterioridad.

1.2.5 Validación experimental y entregables del marco

La viabilidad operativa de la propuesta se evalúa mediante una validación experimental en un entorno controlado de laboratorio, se contempla:

- **Pruebas de concepto (PoC) y latencia:** Medición del impacto computacional y temporal de la verificación criptográfica (HMAC/JWT) para constatar que los tiempos de respuesta se mantengan en la escala de milisegundos, preservando la fluidez del flujo vehicular en horas punta.
- **Evaluaciones de seguridad y riesgos:** Elaboración de matrices de modelado de amenazas bajo metodología STRIDE, matrices de Evaluación de Impacto en la Privacidad (PIA) y análisis de vulnerabilidades sobre la arquitectura propuesta.
- **Cuerpo de directrices normativas:** Documentación técnica integral que habilite la migración tecnológica y la gobernanza continua y adaptable a otros sistemas del proyecto S.I.G.T.E. al interior de la sede Viña del Mar de la Universidad Técnica Federico Santa María.

1.2.6 Delimitación del alcance técnico

Para asegurar la rigurosidad metodológica y viabilidad del proyecto, se establecen con precisión las fronteras operativas, definiendo qué aspectos abarca la solución y qué elementos quedan explícitamente fuera de la investigación:

Incluido en el alcance:

- **Modelado y análisis formal:** Modelado de amenazas sistemático bajo la taxonomía STRIDE sobre los flujos de validación multimodal (LPR, códigos QR dinámicos y credenciales) y evaluación de impacto en la privacidad (PIA).
- **Diseño de controles de seguridad de la información:** Formalización de primitivas criptográficas (firmas HMAC, JWT efímeros con TTL, nonces atómicos), esquema de seudonimización relacional con búsqueda ciega determinista, y directrices de data pruning.
- **Endurecimiento a nivel de aplicación y middleware:** Configuración de controles de autorización RBAC del lado del servidor, esquemas de rate limiting y validación tipada de datos en la arquitectura Next.js 14 / PostgreSQL.
- **Garantía de integridad transaccional:** Mecanismo de sellado y encadenamiento criptográfico de bitácoras con disparadores de sólo inserción (append-only) en base de datos relacional.
- **Compuertas de seguridad en el pipeline:** Configuración de flujos automatizados de análisis estático (SAST) y dependencias (SCA) en GitHub Actions.
- **Validación técnica en laboratorio controlado:** Evaluación empírica de latencia, pruebas de estrés, verificación de bloqueo de replay attacks, control de permisos y simulación de manipulación interna de bases de datos en un entorno de pruebas aislado y reproducible.

Excluido del alcance:

- **Pruebas en entorno productivo real:** Las pruebas de seguridad y de latencia no se ejecutan contra la infraestructura en producción de la universidad para evitar cualquier disrupción en el flujo de acceso real o afección de registros civiles vigentes.

- **Pruebas de penetración ofensiva avanzada (pentesting de caja negra externo):** No se contemplan ataques de intrusión de red física, explotación avanzada de día cero (zero-day), análisis de radiofrecuencia sobre barreras electromecánicas ni ingeniería social sobre el personal de guardia.
- **Auditoría física de hardware de cámaras:** La investigación asume el correcto funcionamiento del firmware y óptica del nodo LPR comercial; no abarca el análisis forense de bajo nivel ni el endurecimiento electrónico del microcontrolador o de la cámara IP.
- **Operación de un Centro de Operaciones de Seguridad (SOC):** La propuesta entrega mecanismos de registro, detección de anomalías y auditabilidad inmutable, pero no incluye el monitoreo continuo 24/7, triage en tiempo real ni la integración con plataformas SIEM empresariales en la nube.
- **Certificaciones formales de cumplimiento:** El trabajo diseña las salvaguardas bajo el enfoque de Compliance by Design alineado con la Ley N° 21.719 y los estándares internacionales ISO/IEC 27001/27701, pero no persigue la acreditación ni certificación legal formal ante organismos certificadores o la futura Agencia de Protección de Datos Personales.

1.3 Objetivos generales y específicos

1.3.1 Objetivo general

A continuación se detalla el objetivo principal de este trabajo de investigación:

Diseñar, formalizar y evaluar un marco integral de ciberseguridad, gobernanza y protección de datos para el tratamiento seguro de identidades y registros de acceso vehicular del proyecto S.I.G.T.E., estableciendo lineamientos técnicos criptográficos, controles de mitigación de amenazas y políticas para el ciclo de vida seguro de identidades y bitácoras de acceso, en estricta conformidad con la normativa legal chilena y los estándares internacionales de seguridad de la información.

1.3.2 Objetivos específicos

El marco de ciberseguridad y gobernanza de la privacidad debe cumplir con los siguientes cinco objetivos específicos:

- **Analizar la superficie de ataque y modelar amenazas:** Identificar y categorizar los vectores de riesgo en los flujos de datos multimodales (LPR, códigos QR y credenciales digitales) mediante la metodología STRIDE y matrices de criticidad de impacto en la privacidad (PIA).
- **Formalizar los controles criptográficos para el tratamiento seguro de identidades y datos privados:** Diseñar los esquemas de generación y verificación de credenciales efímeras basadas en HMAC/JWT con firma digital y caducidad temporal para neutralizar ataques de repetición y clonación en portería, definiendo además políticas de control de acceso basado en roles (RBAC).
- **Establecer las directrices de Gobernanza y Privacidad por Diseño (PbD):** Definir especificaciones técnicas de seudonimización y minimización de datos en las vistas de usuarios (conductores, guardias, administradores e invitados), junto con directrices de ciclo de vida de la información, retención controlada y expurgación periódica de las bitácoras de acceso conforme a la Ley N° 19.628 y 21.719.
- **Endurecer la arquitectura distribuida e infraestructura de datos:** Especificar los controles de protección perimetral y en tránsito (TLS 1.3, HTTPS, mitigación OWASP API Security Top 10) y

directrices de cifrado en reposo para PostgreSQL, integrando validaciones de seguridad en el pipeline CI/CD.

- **Evaluar y validar la resiliencia del marco en entorno controlado:** Ejecutar pruebas de concepto, análisis estático/dinámico de vulnerabilidades y contrastar la latencia de validación criptográfica en laboratorio para verificar la viabilidad operativa y el grado de mitigación alcanzado.

1.4 Justificación y relevancia técnica

La investigación se justifica por la necesidad de dotar a la plataforma de acceso y gestión vehicular S.I.G.T.E. de un marco formal de ciberseguridad, mitigando los riesgos sobre la privacidad y la protección de datos que introduce la modernización multimodal (LPR, QR y credenciales digitales). Su pertinencia se articula en cuatro ejes:

- **Legal:** Asegura el cumplimiento por diseño (compliance by design) frente a la normativa chilena vigente (Ley N° 21.719, que moderniza la Ley N° 19.628). Mitiga el riesgo de infracciones administrativas y cuantiosas sanciones impuestas por la Agencia de Protección de Datos Personales, al regular el tratamiento y perfilamiento de rutinas derivados de la correlación de patentes, RUT, roles y marcas temporales georreferenciadas.
- **Técnico:** Mitiga vectores de ataque comunes en arquitecturas distribuidas (clonación, interceptación y replay attacks) mediante tokens efímeros firmados (HMAC/JWT), control de acceso por roles (RBAC), auditoría con integridad anti-manipulación y análisis preventivo (SAST/SCA en CI/CD) alineado con el OWASP API Top 10.
- **Ético:** Aplica Privacidad desde el Diseño (PbD) para impedir la vigilancia desproporcionada. Implementa minimización de datos en interfaces de control (visibilidad binaria autorizada/denegada para operadores), seudonimización en bases de datos y políticas de expurgo periódico de registros históricos.
- **Operativo:** Valida experimentalmente que los mecanismos criptográficos y de consulta segura operen con latencias mínimas (milisegundos), garantizando que la seguridad no degrade el flujo vehicular en horas punta de la USM (Sede Viña del Mar), además de proveer documentación formal que asegura la interoperabilidad y sostenibilidad del sistema.

1.5 Metodología de desarrollo

Para abordar la problemática de seguridad de forma estructurada, reproducible y verificable, este trabajo adopta un enfoque metodológico mixto organizado por fases y basado en la metodología en cascada (waterfall), sustentado en los paradigmas de Seguridad por Diseño (Security by Design) y Privacidad por Diseño (Privacy by Design - PbD). La ejecución no sigue un ciclo de desarrollo de software convencional, sino una metodología orientada al análisis de riesgos, especificación formal de controles y evaluación en entorno controlado, estructurada en cuatro fases secuenciales:

1.5.1 Fase de Diagnóstico y Modelado de Amenazas

Levantamiento de la arquitectura distribuida preliminar de S.I.G.T.E.. Se aplica la metodología STRIDE de Microsoft sobre los flujos de datos multimodales (LPR, códigos QR y sesiones web) y se ejecuta una Evaluación de Impacto en la Privacidad (PIA) para categorizar riesgos sobre los datos personales procesados.

1.5.2 Fase de Diseño y Especificación de Controles

Formulación técnica de las contramedidas requeridas. Incluye el diseño criptográfico de validación multimodal (tokens efímeros HMAC/JWT con TTL), matrices de control de acceso basado en roles (RBAC), esquemas de disociación/seudonimización en base de datos PostgreSQL y políticas de depuración periódica (data pruning).

1.5.3 Fase de Hardening e Integración Arquitectural

Definición de salvaguardas perimetrales y de capa de aplicación conforme al OWASP API Security Top 10, aseguramiento del transporte mediante TLS 1.3, parametrización de directrices de cifrado en reposo y diseño de compuertas automatizadas de seguridad (SAST y SCA) para el pipeline de CI/CD en GitHub Actions.

1.5.4 Fase de Evaluación Experimental en Laboratorio

Validación técnica de los controles en un entorno controlado y aislado. Comprende pruebas de concepto (PoC) para verificar la neutralización de ataques de repetición (replay attacks), análisis estático de dependencias, simulación de accesos sin privilegio y medición cuantitativa del impacto de los cálculos criptográficos sobre la latencia operativa (verificando el cumplimiento del umbral máximo de 2 segundos estipulado en el RNF-01).

1.6 Organización del informe

El presente informe de trabajo se organiza en seis capítulos temáticos que estructuran la propuesta desde el análisis teórico hasta su validación experimental:

- **Capítulo 1 - Introducción:** Expone el contexto operativo de la sede Viña del Mar, describe el problema derivado de la ausencia de salvaguardas de seguridad en el sistema S.I.G.T.E., detalla los objetivos general y específicos, fundamenta la justificación técnica, legal y ética del proyecto, y describe la metodología de trabajo empleada.
- **Capítulo 2 - Marco teórico:** Fundamenta el rol de la ciberseguridad en la protección de identidades, sintetiza los estándares aplicables (ISO/IEC 27001, ISO/IEC 27701, NIST CSF, OWASP, Ley N° 21.719), y formaliza la arquitectura de controles, patrones criptográficos y el modelo de amenazas bajo el cual se evalúa el sistema.
- **Capítulo 3 - Requerimientos de seguridad y alcance técnico:** Delimita los activos críticos protegidos, traduce los riesgos identificados en requerimientos funcionales y no funcionales de seguridad, formaliza la matriz de riesgos bajo STRIDE y evalúa comparativamente las alternativas técnicas de mitigación.
- **Capítulo 4 - Diseño e implementación:** Constituye el núcleo técnico del trabajo. Detalla la arquitectura de seguridad diseñada, los esquemas criptográficos de credenciales dinámicas, las matrices RBAC, las políticas de seudonimización y minimización de datos, así como la configuración de controles en Next.js, PostgreSQL y GitHub Actions dentro del entorno de laboratorio.
- **Capítulo 5 - Resultados y validación:** Presenta los resultados empíricos derivados de las pruebas de seguridad, incluyendo la eficacia en el bloqueo de repetición de tokens, la verificación de

segregación de roles, las métricas de latencia computacional en portería y la discusión de limitaciones de la validación experimental.

- **Capítulo 6 - Conclusiones y trabajo futuro:** Evalúa el grado de cumplimiento de los objetivos planteados con base en las evidencias recabadas, destaca los principales aportes a la seguridad institucional de la universidad y traza las líneas de trabajo futuro para su eventual transición a entornos productivos.

2. Marco teórico

El presente capítulo formaliza los fundamentos conceptuales, normativos y tecnológicos que sustentan el diseño del marco de ciberseguridad y gobernanza de la privacidad para la plataforma S.I.G.T.E. A través de este marco, se vinculan las necesidades operativas de control de acceso perimetral vehicular con las directrices de la industria y la legislación chilena vigente, estableciendo los patrones técnicos y el modelo de amenazas que orientarán la formulación de los requerimientos y la posterior validación experimental en laboratorio.

2.1 Rol de la ciberseguridad en el sistema

La incorporación de tecnologías digitales en el control de acceso físico traslada la superficie de riesgo institucional desde la caseta de vigilancia hacia los dispositivos de borde, servidores y bases de datos. En S.I.G.T.E., la ciberseguridad opera como un habilitador de confianza y resiliencia institucional estructurado en torno a cuatro objetivos esenciales:

- **Tratamiento seguro y confidencialidad de la identidad:** La correlación sistemática entre matrículas vehiculares, identificadores civiles (RUT), nombres de usuarios y marcas temporales georreferenciadas permite reconstruir patrones de movilidad y permanencia. La ciberseguridad debe impedir la exposición no autorizada o exfiltración masiva de estos perfiles mediante enlaces cifrados de extremo a extremo y esquemas de disociación relacional en la capa de persistencia.
- **Integridad transaccional y no repudio:** La fiscalización mediante captura digital de faltas al reglamento vial y la bitácora de tránsitos demandan certeza probatoria irrefutable ante eventuales litigios administrativos. Las bitácoras no deben ser vulnerables a la alteración retrospectiva (tampering) o supresión deliberada por parte de operadores o usuarios con acceso a la infraestructura.
- **Autenticidad en puntos de control:** La verificación de credenciales en casetas debe certificar que quien solicita el paso corresponde efectivamente al usuario autorizado. Esto exige neutralizar la clonación física de matrículas, la interceptación en tránsito y los ataques de repetición (replay attacks) inherentes a la exhibición de capturas de pantalla de códigos QR estáticos.
- **Disponibilidad y resiliencia del servicio:** Los mecanismos criptográficos y las verificaciones intermedias deben operar dentro de un costo computacional acotado que preserve la fluidez vehicular. La latencia de validación no debe superar el umbral admisible de 2 segundos (RNF-01), impidiendo que la seguridad provoque saturación o bloqueos en las vías de acceso a la sede.

2.2 Marcos, estándares y buenas prácticas aplicables

El diseño del marco defensivo se apoya en un cuerpo armónico de estándares internacionales, catálogos de vulnerabilidades y la normativa legal chilena, asegurando una aproximación metodológica formal y reproducible.

2.2.1 Estándares y Marcos de Referencia de Seguridad de la Información

- **ISO/IEC 27001 e ISO/IEC 27701:** ISO/IEC 27001 aporta la estructura metodológica de controles (Anexo A) orientada a la gestión del riesgo en activos críticos, control de accesos y criptografía, mientras que la extensión ISO/IEC 27701 define las directrices para implementar un Sistema de Gestión de Privacidad de la Información (PIMS), sirviendo de base técnica para materializar el rol institucional de responsable del tratamiento de datos personales y la gobernanza de registros.
- **NIST Cybersecurity Framework (CSF 2.0):** Taxonomía adoptada para categorizar funcionalmente las salvaguardas del sistema, articulando las directrices de Identificar para el diagnóstico de flujos multimodales, Proteger para la aplicación de primitivas criptográficas y políticas RBAC, y Detectar para la verificación continua de integridad en bitácoras de auditoría.
- **OWASP API Security Top 10 (2023):** Catálogo técnico de referencia para proteger la arquitectura desacoplada basada en API Routes, mitigando de forma específica riesgos críticos como autorización rota a nivel de objeto (BOLA/API1), autenticación deficiente (API2), consumo desmedido de recursos mediante rate limiting (API4) y autorización a nivel de función (BFLA/API5).

2.2.2 Principios de Gobernanza y Privacidad

- **Privacidad por Diseño (Privacy by Design - PbD):** Paradigma formulado por Ann Cavoukian e incorporado en las regulaciones modernas que exige concebir la privacidad como la configuración predeterminada y un componente fundacional del ciclo de vida del software, materializándose en S.I.G.T.E. mediante interfaces operativas restringidas, disociación de identificadores en base de datos y directrices automatizadas de ciclo de vida.
- **Seguridad por Diseño (Security by Design - SbD):** Enfoque metodológico complementario al PbD que integra la seguridad como requisito no funcional primario en todas las etapas del ciclo de vida del desarrollo (SDLC), aplicándose mediante modelado de amenazas previo al desarrollo, análisis estático de código (SAST) y análisis de dependencias (SCA) en la cadena de CI/CD.
- **Minimización de Datos:** Principio rector consagrado en la Ley N° 21.719 que exige restringir el tratamiento de datos personales estrictamente a lo necesario, pertinente y adecuado para los fines autorizados; en S.I.G.T.E. se traduce en desacoplar la vista de los guardias (focus mode), suprimiendo la exposición de RUT, carrera o legajo civil para mostrar únicamente un indicador binario de decisión (autorizado / denegado) y el nombre operativo del conductor.
- **Seudonimización:** Técnica de tratamiento mediante la cual los datos personales no pueden atribuirse a un titular determinado sin recurrir a información adicional mantenida de forma separada bajo resguardos técnicos; en el sistema se aplica sustituyendo identificadores directos por UUIDs opacos en las bitácoras de acceso de PostgreSQL para mitigar el impacto de eventuales accesos no autorizados.

- **Evaluación de Impacto en la Privacidad (PIA):** Proceso estructurado de análisis para identificar y mitigar de manera preventiva los riesgos que el procesamiento de datos personales introduce sobre las libertades y derechos de los titulares, justificando su aplicación en S.I.G.T.E. debido a la correlación intensiva de vehículos, identidades civiles y bitácoras georreferenciadas.
- **Control de Acceso Basado en Roles (RBAC):** Modelo de autorización que asigna privilegios a roles funcionales en lugar de hacerlo de manera individual hacia las cuentas, delimitando formalmente en S.I.G.T.E. las capacidades operativas de conductores (consulta de aforo y generación de QR), guardias (validación perimetral e infracciones) y administradores (gestión de usuarios y auditoría).

2.2.3 Mecanismos Criptográficos y Protección de Comunicaciones

- **Códigos de Autenticación de Mensajes (HMAC):** Primitiva criptográfica que combina una función hash segura (SHA-256) con una clave secreta compartida para certificar simultáneamente el origen, autenticidad e integridad de la carga útil, empleándose como fundamento en la firma de credenciales dinámicas, la indexación ciega de patentes y el sellado de bitácoras.
- **Tokens Efímeros y Mitigación Anti-Replay (JWT/TTL):** Estándar RFC 7519 que transmite afirmaciones (claims) firmadas y acotadas mediante una ventana temporal de expiración (Time-to-Live o TTL), integrando un identificador de transacción único (nonce o jti) validado atómicamente contra una tabla de persistencia para garantizar el consumo de un solo uso (single-use) ante capturas visuales de códigos QR.
- **Seguridad en Tránsito y Reposo (TLS 1.3 y AES-GCM):** El cifrado en tránsito mediante HTTPS/TLS 1.3 garantiza la confidencialidad de las tramas entre nodos perimetrales LPR, terminales móviles y API Routes, mientras que el cifrado autenticado de campos sensibles (AES-256-GCM) complementa el cifrado de volumen de la base de datos, protegiendo los datos frente a volcados (dumps) no autorizados.
- **Integridad y No Repudio de Bitácoras (Tamper-Proof Chaining):** Mecanismo de auditoría donde cada evento consecutivo incorpora el resumen criptográfico del registro inmediatamente anterior, empleando un sellado con clave externa segregada ($K_{audit}$$K_{audit}$append-only) en base de datos para impedir que administradores alteren registros pasados sin romper la secuencia matemática.
- **Seguridad en el Ciclo de Construcción (SAST / SCA):** Incorporación de compuertas automatizadas en los flujos de integración continua (CI/CD), aplicando Análisis Estático de Seguridad de Aplicaciones (SAST) para detectar malas prácticas de codificación o secretos embebidos, y Análisis de Composición de Software (SCA) para bloquear dependencias vulnerables antes de su despliegue.

2.2.4 Marco Normativo Legal

- **Ley N° 21.719 (Protección de Datos Personales):** Cuerpo normativo que moderniza la Ley N° 19.628 alineando los estándares nacionales con el RGPD y crea la Agencia de Protección de Datos Personales; al vincular patentes con el RUT e historiales de entrada/salida, la plataforma

actúa como responsable de tratamiento y debe asegurar técnicamente los principios de finalidad, proporcionalidad, minimización y limitación del plazo de conservación.

2.2.5 Tecnologías de la Arquitectura de S.I.G.T.E. y Superficie de Exposición

- **Reconocimiento Automático de Patentes (LPR):** Dispositivos y cámaras IP con OCR encargados de la digitalización óptica de matrículas vehiculares; al asociarse relacionalmente a la identidad de un titular, las patentes se transforman en datos personales protegidos, expuestos a riesgos de perfilamiento, manipulación de tramas de imagen o interceptación en enlaces locales.
- **Códigos QR Dinámicos y Credenciales Institucionales:** Factores alternativos de autenticación multimodal que reemplazan a los esquemas estáticos tradicionales, demandando estructuras dinámicas con firmas criptográficas y expiración estricta para impedir su compartición indebida entre conductores.
- **Arquitectura Serverless desacoplada (Next.js 14, Neon PostgreSQL y Prisma):** Modelo donde la persistencia relacional en la nube y los endpoints de API Routes no comparten estado en memoria entre ejecuciones, condición que incrementa la exposición a ataques de saturación o denegación de servicio (DoS) y obliga a gestionar los límites de tasa y el control anti-repetición de forma transaccional en la capa de datos.
- **Gestión de Sesiones e Identidades (NextAuth.js):** Capa de intermediación de identidades y gestión de tokens JWT de sesión, cuya exposición exige endurecimiento estricto en el manejo de cookies (HttpOnly, Secure), aislamiento de secretos de firma criptográfica y validación rigurosa de claims en servidor para prevenir elevación de privilegios.

2.3 Arquitectura, controles y patrones relevantes

En esta sección se profundiza en los patrones arquitecturales y mecanismos de ingeniería de seguridad que conforman la base defensiva del sistema, explicando cómo operan a nivel técnico para mitigar las debilidades identificadas.

2.3.1 Autenticación dinámica, mitigación anti-repetición y gestión de tokens

- **JSON Web Tokens (JWT) y firmas HMAC:** Estándar que codifica afirmaciones contextuales en un formato estructurado y serializable, garantizando su autenticidad mediante la firma con clave secreta compartida (HMAC-SHA256), lo que permite a las API Routes validar matemáticamente que el contenido no ha sufrido adulteraciones (Tampering) sin necesidad de invocar servicios externos de verificación.
- **Ventanas de caducidad temporal (Time-to-Live - TTL):** Mecanismo de restricción de vigencia parametrizado mediante el claim estándar exp, el cual restringe la validez operativa de los códigos QR dinámicos a una ventana finita (menor o igual a 5 minutos), acotando drásticamente el intervalo útil ante cualquier eventual interceptación física o lógica.
- **Nonces y mitigación de ataques de repetición (Replay Attacks):** Adición de un identificador seudoaleatorio único (jti) en cada token emitido, cuya recepción en el punto de acceso detona un registro atómico con clave única en PostgreSQL; cualquier intento posterior de retransmitir el mismo identificador colisiona y resulta en un rechazo sistemático por token ya consumido.

2.3.2 Modelos de autorización y control de acceso (RBAC)

- **Control de Acceso Basado en Roles (RBAC):** Modelo que desacopla los permisos individuales de los usuarios asociándolos directamente a funciones institucionales predefinidas, permitiendo que la plataforma aplique matrices de privilegios uniformes para regular el acceso a los módulos de consulta, fiscalización y reportería.
- **Validación en el servidor y mitigación BOLA/BFLA:** Evaluación estricta de las credenciales y roles dentro de la lógica del backend y los middlewares en cada petición entrante, garantizando que la ocultación de botones en el frontend no sea la única barrera y bloqueando intentos de invocación directa de endpoints privilegiados por usuarios comunes.

2.3.3 Principios de minimización y técnicas de seudonimización

- **Minimización de datos en interfaces:** Regla de diseño de software orientada a podar los atributos devueltos en las respuestas HTTP, enviando a la PWA del guardia únicamente el nombre, apellido y estado de habilitación, eliminando del tráfico perimetral datos innecesarios como el RUT o carrera académica.
- **Seudonimización e identificadores opacos:** Separación de los datos identificatorios respecto de los registros de tránsito mediante el uso de UUIDs v4 como claves foráneas, garantizando que los logs de movimientos queden disociados de la persona física en caso de una filtración de las tablas de bitácoras.
- **Cifrado en reposo y búsqueda ciega (Blind Indexing):** Protección de la confidencialidad de las matrículas vehiculares en base de datos mediante cifrado simétrico autenticado (AES-256-GCM), combinándose con un campo complementario que indexa el hash determinista (HMAC-SHA256) de la patente para permitir al procesador LPR consultar registros por coincidencia exacta sin descifrar masivamente las tablas en memoria.

2.3.4 Inmutabilidad y encadenamiento criptográfico de bitácoras (Tamper-Proof Chaining)

- **Encadenamiento criptográfico (Hash Chaining):** Estructuración matemática donde cada tupla histórica n incluye el hash del registro precedente ($n-1$ $n-1$
- **Sellado autenticado con clave externa:** Incorporación de un cálculo HMAC gobernado por una clave institucional segregada (K_{audit} K_{audit}
- **Políticas de sólo inserción (Append-Only):** Configuración de disparadores (triggers) y permisos a nivel del motor relacional que prohíben de forma estricta las sentencias de actualización (UPDATE) o eliminación (DELETE) sobre las tablas de auditoría de tránsito y fiscalización.

2.3.5 Hardening de comunicaciones, perímetro de APIs y validación de entradas

- **Seguridad en tránsito (TLS 1.3):** Enforzamiento del protocolo criptográfico más reciente sobre todas las conexiones HTTP y gRPC, garantizando confidencialidad mediante suites de cifrado modernas que soportan Secreto Perfecto hacia Adelante (Perfect Forward Secrecy).
- **Limitación de tasa por sesión y mitigación interactiva (Session-Based Rate Limiting & CAPTCHA):** Restricción contextual a nivel de middleware calculada exclusivamente sobre el identificador de sesión de usuario (sessionId), evitando bloqueos indiscriminados sobre

direcciones IP compartidas por la infraestructura de red universitaria (NAT/proxy perimetral). En lugar de aplicar un bloqueo HTTP 429 estricto ante fallos repetidos, el sistema despliega un desafío automatizado tipo CAPTCHA tras registrar 2 intentos fallidos consecutivos en la sesión, neutralizando la automatización maliciosa sin degradar el acceso de otros usuarios en el mismo segmento de red.

- **Validación y sanitización estricta de esquemas:** Examen sistemático de todas las cargas entrantes mediante esquemas tipados antes de su procesamiento, rechazando peticiones que contengan parámetros inesperados o cargas maliciosas orientadas a inyecciones.

2.3.6 Integración de compuertas de seguridad en el ciclo de desarrollo (DevSecOps)

- **Análisis Estático de Seguridad de Aplicaciones (SAST):** Inspección automatizada del código fuente durante el flujo de CI/CD para detectar vulnerabilidades lógicas, patrones inseguros y secretos o contraseñas hardcodeadas en los repositorios.
- **Análisis de Composición de Software (SCA):** Auditoría continua del inventario de paquetes y dependencias de terceros para identificar y bloquear la incorporación de librerías con vulnerabilidades públicas conocidas (CVEs) antes de su paso a producción.

2.4 Amenazas y modelo de riesgo

Para estructurar de manera rigurosa la postura defensiva de S.I.G.T.E. y preparar la formulación de los requerimientos de seguridad del Capítulo 3, se formaliza un modelo de amenazas sustentado en la metodología STRIDE (desarrollada por Microsoft) en conjunto con un esquema cualitativo y cuantitativo de evaluación de riesgos. Este enfoque permite descomponer sistemáticamente la arquitectura distribuida del sistema, identificar vectores de ataque en los flujos de validación multimodal e inferir el impacto directo sobre los derechos de privacidad de la comunidad universitaria y la continuidad operativa de la sede.

2.4.1 Descomposición del sistema y fronteras de confianza (Trust Boundaries)

El análisis formal de amenazas requiere delimitar las zonas de seguridad donde los datos cambian de nivel de privilegio o viajan a través de canales no confiables:

- **Frontera Perimetral y Dispositivos Físicos:** Comprende el enlace entre las cámaras LPR en caseta, los dispositivos móviles de conductores y guardias (PWA) y el entorno de red de acceso (red institucional Wi-Fi o conectividad celular 4G/5G). Es la zona con mayor exposición a suplantación de identidad y captura de credenciales.
- **Frontera de Servicios Web y Capa de Aplicación:** Comprende la capa de API Routes y middlewares en Next.js (entorno serverless) expuesta a peticiones públicas o semi-autenticadas. Representa el límite de control frente a abusos de consumo, omisión de autorizaciones y ataques categorizados en OWASP API Security.
- **Frontera de Persistencia y Gobernanza:** Delimita el canal de comunicación entre la lógica de negocio y la base de datos PostgreSQL alojada en la nube (Neon). Protege el modelo relacional contra accesos no autorizados a nivel de datos y manipulación retrospectiva de bitácoras.

2.4.2 Clasificación de amenazas bajo la taxonomía STRIDE

Se analizan y categorizan sistemáticamente las amenazas frente a los flujos críticos de S.I.G.T.E.:

- **Spoofing (Suplantación de identidad):** Afecta la validación multimodal en portería. Un atacante retransmite una captura estática de un código QR legítimo (ataque de repetición o replay attack), falsifica placas patentes con duplicados físicos, o clona identificadores de sesión JWT.
- **Tampering (Manipulación de datos):** Alteración maliciosa de tramas en tránsito (parámetros de veredicto en peticiones HTTP), modificación de bitácoras históricas de ingreso para encubrir vehículos no autorizados, o edición arbitraria de boletas de infracción cursadas en PostgreSQL por parte de un actor con acceso privilegiado a la base de datos.
- **Repudiation (Repudio):** Inexistencia de mecanismos de certeza probatoria donde un guardia rechaza haber registrado o eliminado una infracción, o un conductor desconoce su permanencia en el recinto debido a la ausencia de sellado criptográfico inmutable en los registros de auditoría.
- **Information Disclosure (Fuga de información):** Exposición excesiva del legajo personal del conductor (RUT, carrera, sanciones) en la interfaz PWA del guardia al momento del escaneo; interceptación de tráfico no cifrado en tránsito perimetral; o filtración masiva de historiales de desplazamiento georreferenciado por volcado no autorizado (dump) de la base de datos relacional.
- **Denial of Service (Denegación de servicio):** Inundación de peticiones concurrentes contra los endpoints REST de validación perimetral en horas punta (ante la ausencia de limitación de tasa), provocando la indisponibilidad del servicio de apertura y bloqueando el acceso vial a la universidad.
- **Elevation of Privilege (Elevación de privilegios):** Explotación de vulnerabilidades de autorización a nivel de función (OWASP BFLA) que permiten a un usuario con rol de conductor invocar rutas de API reservadas a fiscalizadores o administradores para anular sanciones o registrar accesos arbitrarios.

A continuación, la siguiente tabla sintetiza la matriz de descomposición STRIDE para el ecosistema S.I.G.T.E.:

Tabla 4. Matriz de descomposición de amenazas STRIDE sobre la arquitectura de S.I.G.T.E.

Categoría STRIDE	Componente / Flujo Afectado	Vector de Amenaza Específico	Consecuencia Técnica / Operativa
Spoofing	Flujo QR / Interfaz de Acceso	Retransmisión de capturas visuales de tokens o códigos QR dinámicos ya utilizados (replay attack).	Acceso físico no autorizado al recinto evadiendo el control de portería.
Tampering	Persistencia PostgreSQL / Registros de Acceso	Modificación o eliminación directa de registros en tablas de infracciones y bitácoras de auditoría.	Pérdida de integridad en historiales de sanciones y alteración de estadísticas de aforo.

Repudiation	Módulo de Fiscalización Móvil	Desconocimiento por parte del operador de la emisión de multas o alteración de veredictos sin trazabilidad del actor.	Imposibilidad de sustentar sanciones viales administrativamente ante controversias.
Information Disclosure	Interfaz PWA de Guardia / Tráfico API	Envío de cargas JSON con legajo civil completo (RUT, nombres, carrera) a dispositivos de guardias.	Violación del principio de minimización y exposición indebida según Ley N° 19.628 y Ley N° 21.719.
Denial of Service	Endpoints de Validación (Next.js)	Envío masivo de peticiones concurrentes a las API Routes de resolución de acceso.	Colapso del microservicio de portería y generación de congestión vehicular perimetral.
Elevation of Privilege	Middlewares de Autorización	Conductor autenticado manipula identificadores de rol para ejecutar endpoints administrativos.	Modificación no autorizada de parámetros globales, cupos o listas de fiscalización.

2.4.3 Criterios de Criticidad y Matriz de Riesgo

La priorización de las amenazas modeladas responde a una evaluación matricial formal de Riesgo: $riesgo = probabilidad \times impacto$

Criterios de Probabilidad:

- **Baja (1):** Demanda capacidades avanzadas de intrusión, ruptura de algoritmos criptográficos robustos o acceso físico root a la infraestructura serverless.
- **Media (2):** Explota configuraciones débiles por defecto, ausencia de limitación de tasa (rate limiting) o insuficiencia de validaciones de autorización del lado del servidor.
- **Alta (3):** Ataques de baja complejidad técnica realizables mediante capturas de pantalla de códigos QR compartidas por mensajería, manipulación de URLs o herramientas estándar de navegador.

Criterios de Impacto:

- **Muy Bajo (1):** Eventos con repercusión operativa nula o insignificante. No afecta la fluidez de barrera en portería, no degrada los tiempos de cómputo y no expone ningún tipo de dato personal ni identificador vehicular.
- **Bajo (2):** Afectación operacional leve y aislada. Ocasiona inconsistencias cosméticas o subsanables en los contadores informativos de aforo sectorizado, sin provocar detenciones en el flujo vehicular ni comprometer atributos de identidad civil.
- **Medio (3):** Degradación transitoria de la continuidad del servicio o vulneración de datos operacionales no sensibles. Genera demoras moderadas que se aproximan al umbral de 2 segundos (RNF-01) o accesos no autorizados a estadísticas de ocupación sin exposición de historiales de desplazamiento.

- **Alto (4):** Interrupción severa de la operación perimetral o alteración de la validez probatoria. Provoca congestión vial en los accesos de la sede en horas punta por caída de endpoints de validación, o manipulación/repudio de boletas de infracción y bitácoras que invalida auditorías forenses ante litigios administrativos.
- **Crítico (5):** Vulneración grave con impacto legal y reputacional directo para la universidad. Involucra la exfiltración o exposición masiva de datos personales regulados (RUT, nombres y vinculación con matrículas), construcción de perfiles conductuales de permanencia y movilidad en contravención con la Ley N° 19.628 / Ley N° 21.719, o compromiso total del control perimetral físico por suplantación sistemática de identidades.

Bajo este criterio, los vectores categorizados como de criticidad Crítica y Alta corresponden a la suplantación de credenciales por falta de dinamismo criptográfico, la divulgación de datos personales en vistas desprotegidas y la ausencia de mecanismos de no repudio en las bitácoras operativas. Estos hallazgos sientan la base técnica y justifican directamente los Requerimientos Técnicos y los Requerimientos de Calidad y Validación formalizados en el Capítulo 3.

3. Requerimientos de seguridad y alcance técnico

El presente capítulo formaliza las especificaciones técnicas, operativas y normativas que orientan el diseño y la implementación del marco de ciberseguridad y protección de datos para S.I.G.T.E. Con base en el diagnóstico de vulnerabilidades y el modelado de amenazas realizado previamente, se definen los límites del entorno bajo análisis y se traducen los riesgos identificados en condiciones de seguridad verificables. El objetivo es establecer requisitos claros y trazables que permitan mitigar la superficie de ataque, asegurar el tratamiento de identidades y resguardar la privacidad de los usuarios conforme a la legislación chilena y estándares de la industria, sin comprometer la fluidez operacional en el acceso a la sede.

3.1 Activos, procesos o sistemas bajo análisis

Para delimitar el alcance técnico de la intervención y evitar ambigüedades en la aplicación de los controles, se identifican y categorizan los componentes críticos del ecosistema S.I.G.T.E. que están sujetos a evaluación y protección:

Activos de Información (Datos)

- **Datos de Carácter Personal e Identificadores Civiles:** Conjunto de datos que incluye RUT, nombres completos, roles institucionales (estudiante, docente, funcionario, visita) y credenciales de acceso. Su confidencialidad e integridad son críticas frente a la Ley N° 21.719.
- **Identificadores Vehiculares (Placas Patentes / LPR):** Cadenas alfanuméricas capturadas ópticamente en portería que, al vincularse relacionalmente con una persona natural, constituyen datos personales sensibles a perfilamiento.
- **Bitácoras de Acceso y Marcas Temporales Georreferenciadas:** Registros históricos de eventos de entrada y salida de la sede que revelan hábitos de permanencia y movilidad.
- **Registros de Infracciones y Sanciones Viales:** Evidencias digitales y citaciones cursadas por el personal de seguridad, cuya alteración o supresión afecta la validez probatoria institucional.

Procesos Operativos y Flujos de Datos

- **Flujo de Validación Multimodal en Portería:** Proceso de captura, transmisión y verificación de matrículas vía LPR o lectura de códigos QR efímeros desde dispositivos móviles para autorizar la apertura de barreras en menos de 2 segundos.
- **Fiscalización y Notificación Móvil en Terreno:** Registro dinámico de faltas al reglamento de tránsito ejecutado por los guardias a través de la aplicación web progresiva (PWA).
- **Consulta y Despliegue de Aforos en Tiempo Real:** Cálculo y distribución del estado de ocupación de estacionamientos por sectores sin exponer identificadores individuales.

Sistemas e Infraestructura de Software

- **Capa de Presentación y Clientes (Frontend / PWA):** Aplicaciones cliente ejecutadas en navegadores web y dispositivos móviles de conductores, guardias (modo focus) y administradores, desarrolladas sobre Next.js 14.
- **Capa de Servicios y Lógica de Negocio (Backend API):** Endpoints REST y rutas de servidor desplegadas en entorno serverless, responsables del enrutamiento, validación criptográfica y reglas de negocio.
- **Módulo Periférico de Visión Computacional (LPR):** Nodos y cámaras IP encargados del reconocimiento de matrículas y su comunicación hacia el backend mediante peticiones cifradas.
- **Capa de Persistencia Relacional:** Base de datos PostgreSQL alojada en Neon, administrada mediante Prisma ORM, que actúa como el repositorio central y fuente única de verdad del sistema.

3.2 Requerimientos técnicos y controles a implementar

En concordancia con la pauta de ciberseguridad del departamento, los requerimientos técnicos se articulan como condiciones de seguridad y controles concretos derivados del diagnóstico de riesgos. Cada requerimiento técnico (RT) atiende una debilidad específica de la arquitectura preliminar de S.I.G.T.E., indicando el control técnico asociado, el riesgo que mitiga y el mecanismo de verificación en laboratorio:

Tabla 5. Requerimientos técnicos e implementación

ID	Requerimiento Técnico	Control Técnico a Implementar	Riesgo Mitigado	Mecanismo de Verificación

RT-01	Autenticación criptográfica y tokens efímeros	Firma criptográfica mediante HMAC-SHA256 y JWT con ventana de validez reducida ($TTL \leq 5\ min$) y persistencia transaccional del identificador único de token (jti) en una tabla dedicada de PostgreSQL (UsedNonce) con clave primaria, garantizando consumo único atómico y neutralización de condiciones de carrera en infraestructura serverless.	Spoofing y ataques de repetición (replay attacks) mediante capturas o códigos QR clonados.	Envío de tokens expirados, firmas manipuladas y ráfagas concurrentes retransmitiendo el mismo jti; el sistema debe retornar error HTTP 401/409 por colisión de clave única en la base de datos.
RT-02	Segregación de funciones y mínimos privilegios	Matriz formal de Control de Acceso Basado en Roles (RBAC) implementada a nivel de middleware en Next.js y validación de claims en sesión.	Elevation of Privilege, abuso de funciones administrativas y Broken Function Level Authorization (OWASP API5).	Pruebas de invocación de endpoints administrativos y de fiscalización utilizando credenciales con rol conductor.
RT-03	Minimización de datos en interfaces de guardia	Desacoplamiento de vistas en PWA (focus mode), restringiendo la respuesta del endpoint a una tupla binaria de veredicto operativo (autorizado: boolean, nombreApellido: string).	Information Disclosure, perfilamiento indebido y exposición masiva de datos personales en caseta.	Inspección de tramas HTTP/JSON recibidas en el cliente del guardia para constatar ausencia de RUT, nombres o carreras.
RT-04	Disociación y seudonimización integral en reposo	Reestructuración del esquema relacional en Prisma/PostgreSQL implementando seudonimización mediante identificadores opacos (UUID v4) para conductores, personal de guardia y administradores, desacoplando sus datos personales civiles de los registros de auditoría y transacciones	Exfiltración, perfilamiento y acceso no autorizado a identidades y roles (conductores, guardias y administradores) o hábitos de tránsito ante brechas o volcados no autorizados de la base de datos (Ley N° 21.719).	Extracción de un dump de la tabla de accesos y tránsito para verificar la ausencia de patentes y RUTs en texto claro, y ejecución de pruebas de consulta directa mediante coincidencia de hash determinista.

		operativas. Cifrado en reposo (AES-256-GCM) para la patente vehicular y datos de identidad sensibles, complementado con un índice ciego/determinista mediante HMAC-SHA256 con sal secreta institucional para búsquedas operativas.		
RT-05	Ciclo de vida y depuración controlada (Data Pruning)	Procedimientos programados para la purga automatizada o anonimización irreversible de eventos de tránsito que superen el periodo de retención justificado.	Almacenamiento indefinido de perfiles temporales y vulneración del principio de limitación del plazo de conservación.	Ejecución de rutinas de expurgación en base de datos sobre registros simulados antiguos, constatando su eliminación segura.
RT-06	Integridad y no repudio de bitácoras (Tamper-Proof)	Estructura de bitácora encadenada mediante HMAC-SHA256 con llave secreta externa, combinada con el desacoplamiento de privilegios de usuario en PostgreSQL (restricción estricta a operaciones INSERT/SELECT) y activación de triggers preventivos que prohíben mutaciones (UPDATE/DELETE), garantizando no repudio e inalterabilidad de eventos incluso ante accesos privilegiados a nivel de aplicación.	Tampering y Repudiation de infracciones cursadas o eventos de acceso vehicular por usuarios con privilegios.	Intento de ejecución de sentencias UPDATE/DELETE desde la aplicación para verificar rechazo a nivel de privilegios y triggers en PostgreSQL. Modificación deliberada de una tupla histórica mediante superusuario de base de datos; el algoritmo auditor debe alertar inmediatamente la ruptura de la secuencia HMAC al no coincidir el hash esperado ni poder regenerarlo sin la clave K_{audit}.
RT-07	Hardening de endpoints y mitigación OWASP API	Middleware de limitación de tasa discriminado estrictamente por	Denegación de servicio (DoS por saturación), consumo irrestricto	Envío de secuencias de credenciales o tokens inválidos

		identificador de sesión de usuario. Incorporación de un controlador de fallos que, tras detectar 2 intentos fallidos consecutivos sobre una sesión específica, exige y valida un desafío interactivo (CAPTCHA) antes de permitir nuevas evaluaciones, junto con validación estricta de esquemas Zod en backend.	de recursos y explotación de BOLA/IDOR.	bajo la misma sesión en el cliente; verificación de que al 2° fallo el sistema intercepta las peticiones requiriendo resolución de CAPTCHA, mientras que solicitudes concurrentes desde la misma IP bajo otra sesión continúan operando sin interrupción.
RT-08	Cifrado en tránsito y reposo	Enforzamiento estricto de HTTPS sobre TLS 1.3 con suites de cifrado seguras y activación de cifrado de volumen en PostgreSQL (Neon).	Interceptación de tramas por canal inseguro (sniffing en redes locales o públicas) y robo de soportes de datos.	Análisis de configuración SSL/TLS con herramientas de auditoría y revisión de parámetros de conexión segura.
RT-09	Compuertas de seguridad en el pipeline CI/CD	Integración de análisis estático (SAST) y análisis de dependencias (SCA) automatizados en flujos de GitHub Actions.	Despliegue de librerías desactualizadas con vulnerabilidades conocidas (CVEs) o secretos hardcodeados.	Inyección deliberada de una dependencia vulnerable o secreto de prueba para constatar el bloqueo automático del pipeline.

Criterios de Especificación Técnica

- **Trazabilidad directa:** Cada control se mapea contra un vector tipificado previamente en el modelado STRIDE (2.4.1), asegurando que el marco resuelva problemas reales de la arquitectura de S.I.G.T.E..
- **Restricción de entorno:** Todos los controles están diseñados para su configuración y validación en el entorno de laboratorio de pruebas, sin requerir despliegues productivos que afecten la operación real de la sede.
- **No redundancia funcional:** Los mecanismos de seguridad actúan como salvaguardas perimetrales e intermedias (middlewares, firmas, esquemas) sin interferir en la lógica de negocio central de fiscalización y gestión de estacionamientos.

3.3 Requerimientos de calidad, operación y validación

Los requerimientos de calidad y operación definen los atributos no funcionales, los umbrales de rendimiento admisible y los criterios cuantitativos necesarios para constatar que los controles implementados no degraden la continuidad operativa del sistema ni su viabilidad práctica en la sede universitaria.

A continuación se declara cada requerimiento individual, con su respectivo criterio de verificación y método de validación:

Tabla 6. Requerimientos de calidad, operación y validación

ID	Dimensión / Atributo	Requisito Operacional	Métrica / Criterio Verificable	Método de Validación
RQ-01	Tiempo de Respuesta (Latencia Backend)	La deserialización de payloads, validación de firmas HMAC-SHA256, inserción atómica de nonces (jti) en la tabla relacional de PostgreSQL y consultas relacionales indexadas no deben degradar la capacidad de cómputo del servidor (Latencia backend en $\leq 200\ ms$)	Latencia interna de backend en el percentil 95 (P_{95}) bajo ráfagas concurrentes de hasta 50 req/s.	Benchmark en laboratorio con k6 / Autocannon sobre endpoints de validación.
RQ-02	Tiempo de Respuesta (Ciclo de Barrera)	El ciclo operativo completo (adquisición LPR o escaneo de código QR en PWA + transmisión TLS + veredicto + orden de apertura física) debe garantizar fluidez vehicular en horas punta.	Tiempo total de veredicto perimetral $\leq 2\ s$ (conforme a RNF-01).	Medición con cronómetro de red y trazas distribuidas cliente-servidor.

RQ-03	Confidencialidad y Minimización	La interfaz de los guardias en terreno y los payloads JSON transmitidos hacia la PWA móvil no deben exponer datos de identificación civil ni atributos personales innecesarios.	0% de exposición de atributos civiles sensibles (RUT, nombres completos, roles académicos o infracciones previas). Solo se transmite: veredicto: boolean y nombre con apellido.	DAST e inspección de tráfico HTTP con OWASP ZAP / Burp Suite en vistas de guardia.
RQ-04	Integridad y No Repudio (Auditabilidad)	Las bitácoras de eventos de acceso vehicular, lecturas LPR y boletas de infracción cursadas deben estructurarse de modo que cualquier alteración histórica interna sea detectada inmediatamente.	100% de detección determinista de manipulación mediante rotura de la cadena de integridad HMAC-SHA256 ante alteraciones directas de datos históricos en PostgreSQL, e imposibilidad técnica de recalcular la cadena sin la clave secreta institucional de auditoría (K_{audit}).	Script de auditoría automatizado que altera campos de eventos pasados simulando un ataque interno, verificando el disparo inmediato de una alerta de pérdida de integridad forense.
RQ-05	Eficacia Criptográfica (Anti-Replay)	Los códigos QR dinámicos y tokens efímeros generados por conductores deben ser de un solo uso e inviables fuera de su periodo de vigencia.	100% de bloqueo ante retransmisión de tokens (repetición del mismo nonce/jti) o peticiones fuera de la ventana de expiración ($\Delta t \leq 5 \text{ min}$).	Testbed automatizado inyectando peticiones concurrentes con capturas QR previas y tokens duplicados, verificando el rechazo sistemático por restricción de unicidad en la tabla de nonces y el registro de la anomalía en bitácoras.

RQ-06	Control de Acceso Granular (RBAC)	Las reglas de autorización deben evaluarse estrictamente a nivel de middleware en el servidor, neutralizando accesos horizontales y verticales indebidos (BOLA/BFLA).	100% de denegaciones forzadas (HTTP 401 Unauthorized / HTTP 403 Forbidden) ante intentos de invocación de endpoints administrativos o de fiscalización con cuentas de rol conductor.	Suite de pruebas de integración con Postman/Newman ejecutando matrices de permisos cruzados.
RQ-07	Cobertura de Logs y Trazabilidad	El sistema debe registrar eventos significativos de seguridad de forma exhaustiva para análisis forense, sin registrar información confidencial en texto claro.	Cobertura de eventos de seguridad ≥ 95 : accesos denegados, fallos de autenticación, eventos de activación de CAPTCHA por sesión y cambios de estado, conteniendo timestamp ISO 8601, IP de origen, identificador de sesión seudonimizado, hash del actor y acción.	Revisión analítica de la tabla de bitácoras frente a una batería de eventos simulados.
RQ-08	Resiliencia y Disponibilidad	En caso de degradación de red perimetral o falla del servicio LPR, el sistema debe alternar de forma transparente hacia métodos secundarios sin paralizar el acceso vehicular.	Disponibilidad del flujo de validación $\geq 95\%$ en horario operacional. Mecanismo de fallback a escaneo QR/cédula operativo en $\leq 5\ s$ ante caída de cámara	Simulación de desconexión forzada de nodo LPR y verificación de conmutación en la PWA del guardia.

RQ-09	Severidad de Hallazgos y Calidad en CI/CD	El código fuente y las dependencias de terceros en repositorios no deben introducir vulnerabilidades conocidas ni credenciales expuestas en el repositorio.	0 vulnerabilidades de severidad Crítica o Alta (CVEs) en análisis SCA y ausencia total de credenciales expuestas (0 hardcoded secrets) en el Quality Gate de SonarQube/GitHub Actions.	Ejecución del pipeline de CI/CD con SonarQube Scanner y OWASP Dependency-Check.
RQ-10	Nivel de Cumplimiento Normativo (Compliance by Design)	El tratamiento, almacenamiento, seudonimización y política de expurgo periódico de patentes y datos personales de conductores, guardias y administradores debe alinearse con los principios de licitud, proporcionalidad, minimización y responsabilidad proactiva tipificados en la Ley N° 21.719.	Cumplimiento del 100% de los controles evaluados respecto a los principios de finalidad, minimización y retención temporal (data pruning de registros $\geq 3\ años$), garantizando trazabilidad auditable y capacidad de respuesta frente a eventuales requerimientos de la Agencia de Protección de Datos Personales.	Auditoría de esquema relacional seudonimizado y verificación de rutinas de expurgación programadas.

Criterios de Aceptación y Protocolo de Validación en Laboratorio

Para evitar sesgos o interpretaciones cualitativas en la evaluación de la solución, la aprobación de las pruebas experimentales en laboratorio se sujeta a tres compuertas de validación objetivas:

- **Compuerta de Eficacia de Bloqueo y Resiliencia Criptográfica:** El entorno experimental debe demostrar el rechazo sistemático del 100% de ataques simulados de repetición (replay attacks), credenciales vencidas y firmas HMAC adulteradas, manteniendo una tasa de falsos positivos en 0% para conductores legítimos.
- **Compuerta de Integridad Forense y Aislamiento de Privacidad:** La verificación determinista de la rotura de cadena de hashes ante modificaciones en PostgreSQL debe tener un 100% de asertividad. Paralelamente, el tráfico de red auditado hacia las interfaces de los guardias no debe contener identificadores directos (RUT o legajo académico).
- **Compuerta de Calidad de Software y No Regresión Operativa:** El pipeline de integración continua debe certificar que las dependencias npm y el código no incorporen fallos tipificados en

el OWASP API Security Top 10, asegurando además que la latencia acumulada en servidor se sitúe por debajo de los 200 ms bajo carga normal de laboratorio.

3.4 Criterios de evaluación

La siguiente tabla formaliza los marcos normativos, estándares industriales y modelos de evaluación técnica que actúan como base comparativa para medir la eficacia y el nivel de mitigación del marco diseñado. Cada marco seleccionado cumple una función específica dentro de la arquitectura de S.I.G.T.E.:

Tabla 7. Criterios de evaluación

Marco / Estándar de Referencia	Ámbito de Aplicación en S.I.G.T.E.	Criterio de Evaluación y Métrica de Cumplimiento
Metodología STRIDE (Microsoft)	Modelado de amenazas sobre el flujo de validación multimodal y arquitectura de red.	Tasa de mitigación de vectores identificados: constatación de que cada amenaza tipificada (Spoofing, Tampering, etc.) cuenta con al menos un control técnico verificable en el diseño.
OWASP API Security Top 10 (2023)	Hardening y validación de seguridad sobre endpoints REST en Next.js.	Ausencia de vulnerabilidades críticas: verificación de no exposición frente a fallos de autorización (BOLA/BFLA), ausencia de rate limiting y manipulación de parámetros de consulta.
NIST Cybersecurity Framework (CSF 2.0)	Estructuración operativa y taxonómica de controles técnicos.	Cobertura funcional en las categorías de Gobernar, Identificar (activos y flujos), Proteger (criptografía, RBAC, hardening) y Detectar (bitácoras y monitoreo).
ISO/IEC 27001 (Anexo A) e ISO/IEC 27701	Gobernanza de la seguridad de la información y gestión de la privacidad (PIMS).	Grado de alineación con directrices de control de acceso, gestión criptográfica, minimización de datos y derechos de los titulares en entornos institucionales.
Marco Normativo Chileno: Ley N° 21.719 (Protección de Datos Personales).	Cumplimiento normativo y responsabilidad legal en el tratamiento de identidades.	Demostración de Compliance by Design y responsabilidad proactiva (accountability): constatación técnica de no retención innecesaria de datos, disociación de identificadores de tránsito, minimización de datos en interfaces operativas y mitigación preventiva de incidentes de seguridad que deban ser notificados a la Agencia de

		Protección de Datos Personales o al CSIRT Nacional.
Métricas de Rendimiento Operativo (RNF-01)	Viabilidad en terreno y fluidez vehicular en el acceso a la sede.	Umbral de latencia estricto: tiempo de procesamiento de verificación criptográfica (HMAC/JWT) $\leq 200\ ms$ y tiempo de ciclo completo en barrera $\leq 2\ s$.

3.4.1 Criterios de Aceptación para la Validación Experimental

Para evitar evaluaciones subjetivas o afirmaciones genéricas de seguridad, la validez del marco propuesto se determinará en el laboratorio bajo tres condiciones de aceptación objetivas:

- **Eficacia de Bloqueo frente a Abuso:** El sistema debe rechazar el 100% de los intentos de inyección de tokens expirados, firmas HMAC adulteradas, códigos QR interceptados con nonces ya consumidos y peticiones sin cabeceras de autorización válidas.
- **Preservación Estricta de la Privacidad:** Inspecciones pasivas y activas del tráfico JSON hacia los terminales de guardia deben evidenciar un 0% de filtración de datos de identificación civil (RUT, nombre, carrera), validando el aislamiento del modo operativo (focus mode).
- **Inalterabilidad de Evidencias Forenses:** Ante modificaciones deliberadas de registros históricos en la base de datos PostgreSQL mediante sentencias directas, el algoritmo de auditoría debe reportar la ruptura de la cadena criptográfica de hashes (tamper detection) de manera determinista.

3.5 Matriz de riesgos y amenazas

La tabla que se presenta a continuación muestra el cálculo realizado para el nivel de riesgo de cada tipo de activo según su probabilidad de ocurrencia y el impacto operativo que generaría un incidente:

Tabla 8. Cálculo del nivel de riesgo para los activos

Activo	Probabilidad	Impacto	Nivel de Riesgo
Credenciales y Tokens de Acceso.	Alta (3)	Crítico (5)	Crítico
Datos de Carácter Personal (RUT, Nombre)	Alta (3)	Crítico (5)	Crítico

Bitácoras de Acceso y Multas	Media (2)	Alto (4)	Alto
Base de Datos y Perfiles de Movilidad	Media (2)	Alto (4)	Alto
API Endpoints (Next.js)	Media (2)	Alto (4)	Alto
Funciones Administrativas	Media (2)	Alto (4)	Alto
Tráfico de Red y Enlaces Periféricos	Media (2)	Medio (3)	Medio

La tabla a continuación consolida en una sola matriz la trazabilidad integral de seguridad de S.I.G.T.E., se vinculan los activos críticos bajo análisis (3.1), los vectores de amenaza catalogados según STRIDE (2.4.2) y las vulnerabilidades detectadas en la arquitectura preliminar, ponderando su probabilidad e impacto para establecer el nivel de riesgo global, junto con el control técnico asignado y la evidencia objetiva a obtener en la validación experimental de laboratorio.

Tabla 9. Matriz integral de riesgos, amenazas, controles y evidencias de validación

Activo Afectado	**Amenaza (STRIDE)**	**Vulnerabilidad del Sistema**	**Nivel de Riesgo**	**Control Técnico Propuesto**	**Evidencia de Validación en Laboratorio**
Credenciales y Tokens de Acceso	Spoofing: Clonación de credenciales dinámicas y suplantación física en portería.	Códigos QR estáticos o tokens sin ligadura criptográfica ni validación de un solo uso.	Crítico	Tokens efímeros firmados mediante HMAC-SHA256 con ventana TTL acotada ($\leq 5\ min$) y verificación atómica de uso único del claim jti en tabla transaccional de PostgreSQL con índice único y expurgo programado.	Inyección de capturas QR previas y tokens duplicados; verificación sistemática del rechazo del 100% de reintentos (replay attack) con código HTTP 401/409.

Identidades y Datos de Carácter Personal (Conductores, Guardias y Administradores)	Information Disclosure: Filtración y perfilamiento por exposición excesiva de datos.	Interfaz del guardia expone el legajo completo del usuario (RUT, nombre, carrera) al escanear credenciales.	Crítico	Seudonimización relacional mediante identificadores opacos (UUID v4) aplicada a todos los perfiles del sistema (conductores, guardias y administradores), aislando tablas de identidad civil de las bitácoras transaccionales. Almacenamiento de atributos identificadores con cifrado de columna (AES-256-GCM) y campo de búsqueda ciego indexado con HMAC-SHA256 con sal institucional fija.	DAST e inspección de tramas HTTP/JSON en el cliente del guardia con Burp/ZAP; constatación de 0% de filtración de atributos civiles.
Bitácoras de Acceso y Multas	Tampering / Repudiation: Modificación maliciosa o eliminación de infracciones y registros de tránsito.	Bitácoras almacenadas como registros convencionales editables en la base de datos sin sellado criptográfico.	Alto	Bitácoras inmutables encadenadas mediante HMAC-SHA256 con clave externa segregada ($H_n = HMAC-SHA256_{K_{audit}}(D_n \parallel H_{n-1})$), combinada con esquema append-only y triggers que prohíben mutaciones (UPDATE/DELETE).	Modificación forzada de tuplas históricas en PostgreSQL; verificación de alerta determinista por ruptura de cadena de hashes y rechazo inmediato por trigger.
Base de Datos y Perfiles de Movilidad	Information Disclosure: Exfiltración masiva de historiales de desplazamiento ante brechas en la base de datos.	Identificadores civiles y matrículas vinculados en texto claro en reposo sin mecanismos de disociación.	Alto	Seudonimización relacional con UUIDs v4, almacenamiento de patentes mediante cifrado de columna (AES-256-GCM) y campo de búsqueda ciego indexado mediante HMAC-SHA256 con sal institucional fija.	Auditoría de volcado (dump) SQL de tablas de tránsito constatando ausencia de matrículas y RUTs legibles, y validación de consultas ciegas en laboratorio por debajo de 15 ms.
API Endpoints (Next.js)	Denial of Service:	Rutas de autenticación y	Alto	Implementación de middleware en	Pruebas de inyección de

	Saturación de endpoints de validación perimetral en horas punta.	validación perimetral sin control granular por sesión o susceptibles a bloqueos cruzados por NAT compartido.		Next.js con rate-limiting focalizado por sesión de usuario. Configuración de umbral restrictivo que dispara la exigencia de un CAPTCHA al segundo (2°) intento fallido en la sesión, evitando el bloqueo generalizado por IP universitaria.	intentos fallidos automatizados: constatación del requerimiento de CAPTCHA al segundo intento fallido sobre la sesión evaluada y verificación de no afectación a sesiones concurrentes originadas desde la misma IP pública institucional.
Funciones Administrativas	Elevation of Privilege: Conductor invoca funciones restringidas de fiscalización o administración.	Verificación de autorizaciones delegada exclusivamente al cliente o ausente en endpoints internos del servidor.	Alto	Control de Acceso Basado en Roles (RBAC) validado estrictamente en servidor y middlewares para cada recurso y acción solicitada.	Invocación de rutas protegidas mediante credenciales emitidas para rol conductor; comprobación de respuesta sistemática HTTP 403 (Forbidden).
Tráfico de Red y Enlaces Periféricos	Information Disclosure: Interceptación de tramas de credenciales o lecturas LPR en tránsito.	Coexistencia potencial de canales HTTP no cifrados en redes locales o enlaces periféricos.	Medio	Enforzamiento estricto de cifrado en tránsito mediante HTTPS y protocolo TLS 1.3 con suites criptográficas robustas y HSTS.	Análisis de configuración SSL/TLS con herramientas de auditoría, verificación de suites activas y redirección obligatoria desde HTTP.

3.6 Tabla comparativa de alternativas técnicas

Para justificar las decisiones de diseño del marco de ciberseguridad, se evalúan las alternativas tecnológicas y metodológicas disponibles para cada dimensión crítica, aplicando criterios de seguridad, latencia operativa (impacto en latencia según RNF-01), complejidad de implementación y sobrecarga arquitectural:

Tabla 10. Comparativa de alternativas evaluadas, criterios de decisión y elección

Componente / Mecanismo	Alternativas Evaluadas	Criterios de Decisión y Análisis Técnico	Elección Justificada

Autenticación Multimodal (Códigos QR)	• Códigos QR Estáticos. • Códigos Dinámicos TOTP (RFC 6238). • Tokens Dinámicos Efímeros (HMAC/JWT).	Los QR estáticos carecen de mitigación contra replay attacks. TOTP requiere sincronización estricta de relojes cliente-servidor y limita el payload a números. HMAC/JWT permite incluir metadatos contextuales (identificador, rol, nonce y TTL) firmados criptográficamente.	Tokens Dinámicos Efímeros (HMAC/JWT): Provee ligadura criptográfica a la identidad, verificación rápida en milisegundos y caducidad temporal estricta de un solo uso.
Control de Acceso y Autorización	• Listas de Control de Acceso (ACL). • Control Basado en Atributos (ABAC). • Control Basado en Roles (RBAC).	ACL es rígido e inmanejable a escala comunitaria. ABAC ofrece alta granularidad pero introduce sobrecarga computacional y complejidad innecesaria para las reglas operativas de la sede. RBAC modela naturalmente los tres perfiles bien diferenciados del sistema.	RBAC (Role-Based Access Control): Óptima segregación entre conductor, guardia y administrador, con mínima sobrecarga de procesamiento en API middlewares.
Protección de Datos en Reposo	• Texto claro sin tratamiento. • Anonimización irreversible. • Seudonimización con Identificadores Opacos.	El texto claro infringe el marco normativo (Ley N° 21.719). La anonimización irreversible impide la trazabilidad forense y el registro de reincidencias en infracciones. La seudonimización disocia los datos civiles de los registros de tránsito.	Seudonimización Relacional con Búsqueda Ciega (HMAC determinista + AES-GCM): Cumple con el principio de Privacidad por Diseño (PbD) y la Ley N° 21.719. Permite indexación rápida y búsqueda de coincidencia exacta por parte del procesador LPR sin descifrar registros en memoria

Integridad de Bitácoras de Auditoría	• Base de datos relacional tradicional (CRUD). • Blockchain permisionada externa. • Bitácora Encadenada Criptográficamente (Hash Chaining).	Las tablas tradicionales permiten alteración directa por administradores (tampering). La blockchain externa introduce latencias de consenso de varios segundos y costos operacionales incompatibles con la portería. El encadenamiento local vía SHA-256 es ligero e inmutable.	Bitácora Encadenada HMAC-SHA256 con Esquema Append-Only en PostgreSQL: A diferencia de SHA-256 plano (susceptible a recomputación lineal si se vulnera la base de datos), el encadenamiento mediante HMAC con clave externa ligada a un esquema de solo inserción (INSERT-only) a nivel de base de datos neutraliza el tampering interno y garantiza no repudio probatorio sin introducir las latencias de consenso de varios segundos ni los costes de una red blockchain.
Validación de Seguridad en Código (CI/CD)	• Auditorías manuales periódicas. • Pruebas dinámicas manuales (Burp Suite únicamente). • Compuertas Automatizadas SAST/SCA en GitHub Actions.	Las revisiones manuales no escalan y permiten el paso de dependencias vulnerables a producción. Las compuertas automatizadas bloquean vulnerabilidades tipificadas (OWASP) de forma continua en cada integración de código.	Pipeline DevSecOps Automatizado: Asegura trazabilidad y cumplimiento de estándares de código seguro antes del despliegue en entorno de laboratorio.
Mecanismo de Almacenamiento de Estado para Nonces (Anti-Replay)	• Memoria local de la función (In-Memory Map). • Almacén clave-valor externo distribuido (Redis / Upstash). • Tabla relacional transaccional en base de datos central (PostgreSQL).	La memoria local falla por la naturaleza efímera y no compartida de los contenedores serverless en Next.js/Vercel (incumpliría anti-replay entre instancias distintas). Redis externo añade una dependencia de infraestructura de red adicional, costos operativos extra y un punto de falla externo. PostgreSQL es la fuente única de verdad del sistema, cuenta con garantías transaccionales ACID y soporte para restricciones de unicidad atómicas. Dado el volumen de accesos en portería, la sobrecarga es insignificante ($\leq 5\ ms$ por	Tabla de Nonces Transaccional en PostgreSQL: Aprovecha la infraestructura existente sin añadir dependencias externas; garantiza atomicidad estricta (previniendo race conditions) y permite un mantenimiento simplificado con rutinas periódicas de depuración (DELETE WHERE expires_at < NOW()).

		inserción indexada)	

4. Diseño e implementación

4.1 Diseño de la solución de seguridad

El diseño de seguridad para la plataforma S.I.G.T.E. aborda de manera sistemática los riesgos derivados de la validación vehicular multimodal y la correlación centralizada de identidades, matrículas y bitácoras. La solución se articula bajo los paradigmas de Security by Design y Privacy by Design (PbD), estructurando perímetros de confianza formales y desacoplando la lógica de mitigación criptográfica, la autorización perimetral en servidor y la gobernanza de la persistencia de datos.

4.1.1 Arquitectura y componentes

La arquitectura de seguridad delimita el sistema en tres capas lógicas principales:

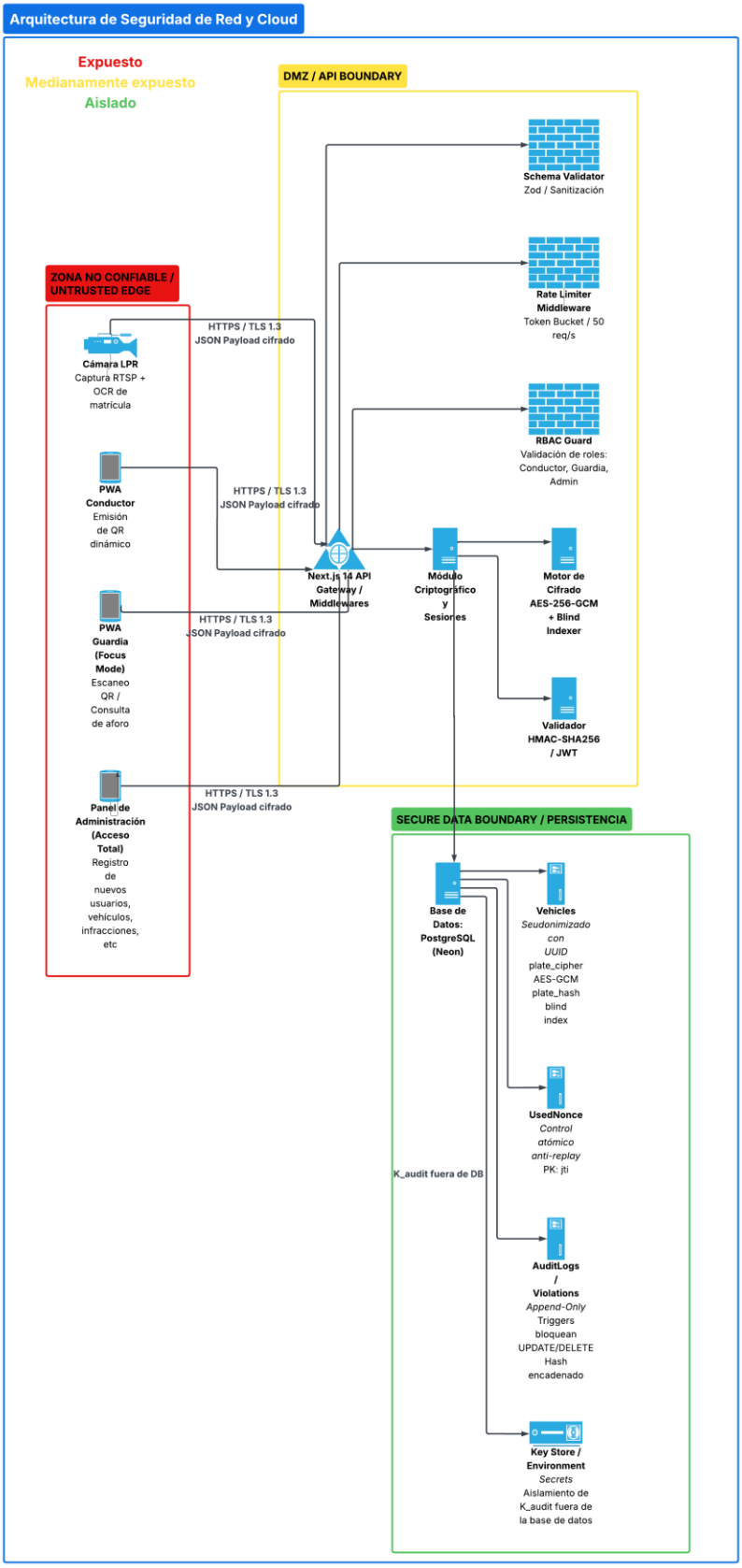
- Capa Perimetral y Dispositivos de Borde (Untrusted Edge):
  - Nodos de Captura Vehicular / LPR: Dispositivos y cámaras IP de portería encargados del reconocimiento óptico de matrículas. Transmiten las lecturas capturadas mediante peticiones cifradas (HTTPS/TLS) hacia las interfaces del backend.
  - Clientes PWA (Conductores y Guardias): Aplicaciones web progresivas desarrolladas en React 19 y Next.js 16. Para el personal de portería, la interfaz opera en modo enfocado (Focus Mode), adaptada operativamente para mitigar la sobreexposición visual de datos personales en caseta.
- Capa de Servicios y Lógica de Negocio (Secure Middleware & API Boundary):
  - API Routes y Middlewares en Next.js: Punto de entrada a la zona protegida. Utiliza funciones de orden superior (higher-order functions, como withAuth) para interceptar peticiones, validar esquemas de entrada fuertemente tipados mediante Zod, gestionar cookies de sesión seguras (httpOnly, SameSite=Lax) y aplicar políticas de control de acceso basado en roles (RBAC). Integra un middleware perimetral de limitación de tasa discriminado exclusivamente por sesión activa (sessionId), el cual, tras registrar 2 intentos fallidos consecutivos sobre dicha sesión, intercepta las peticiones subsecuentes

exigiendo la resolución obligatoria de un desafío interactivo (CAPTCHA), evitando así la denegación de servicio por bloqueo de IP compartida en la red institucional.

- Módulo de Autenticación e Identidad: Implementación nativa basada en el estándar JSON Web Token (JWT) mediante la librería criptográfica jose, complementada con funciones de derivación de claves seguras con bcryptjs (factor de trabajo / coste de salt = 10) y delegación hacia el middleware de desafío CAPTCHA por sesión ante intentos fallidos reiterados.
- Servicio de Emisión y Validación de Códigos QR: Generador y validador de tokens efímeros firmados mediante HMAC-SHA256, con una ventana de vigencia temporal estricta de 5 minutos ($TTL \leq 5 \text{ min}$) y comparación de firmas en tiempo constante (timingSafeEqual) para prevenir ataques de canal lateral por análisis de tiempo.

- Capa de Persistencia y Almacenamiento (Data Trust Boundary):
  - Motor Relacional PostgreSQL 16 Contenerizado: Base de datos desplegada en contenedor Docker aislado (postgres:16-alpine), administrada mediante Prisma ORM. Implementa una estrategia integral de seudonimización mediante identificadores compactos y opacos resistentes a colisiones (CUID / UUID v4) en el modelo relacional (id String @id @default(cuid())), desacoplando de manera transversal los datos de identidad civil de conductores, guardias y administradores de las bitácoras operativas y transaccionales para prevenir la enumeración secuencial y la correlación directa en caso de brechas.
  - Tablas de Auditoría y Control de Acceso (AccessLog e Infraction): Bitácoras transaccionales que preservan el historial de tránsitos, la modalidad de acceso (QR o PLATE) y las infracciones cursadas por los inspectores en terreno.

Figura 2. Diagrama de arquitectura de seguridad de Red y Cloud


Arquitectura de Seguridad de Red y Cloud
Expuesto
Medianamente expuesto
Aislado
DMZ / API BOUNDARY
ZONA NO CONFIABLE / UNTRUSTED EDGE
Schema Validator
Zod / Sanitización
Rate Limiter Middleware
Token Bucket / 50 req/s
RBAC Guard
Validación de roles: Conductor, Guardia, Admin
HTTPS / TLS 1.3
JSON Payload cifrado
Cámara LPR
Captura RTSP + OCR de matrícula
PWA Conductor
Emisión de QR dinámico
PWA Guardia (Focus Mode)
Escaneo QR / Consulta de aforo
Panel de Administración (Acceso Total)
Registro de nuevos usuarios, vehículos, infracciones, etc
Next.js 14 API Gateway / Middlewares
Módulo Criptográfico y Sesiones
Motor de Cifrado AES-256-GCM + Blind Indexer
Validador HMAC-SHA256 / JWT
SECURE DATA BOUNDARY / PERSISTENCIA
Base de Datos: PostgreSQL (Neon)
Vehicles
Seudonimizado con UUID
plate_cipher AES-GCM
plate_hash blind index
UsedNonce
Control atómico anti-replay
PK: jti
K_audit fuera de DB
AuditLogs / Violations
Append-Only
Triggers bloquean UPDATE/DELETE
Hash encadenado
Key Store / Environment
Secrets
Aislamiento de K_audit fuera de la base de datos

4.1.2 Controles implementados

En concordancia con los requerimientos técnicos formalizados en el Capítulo 3 y los vectores de riesgo categorizados bajo STRIDE, se implementó un conjunto coordinado de controles defensivos a nivel de aplicación, middleware y capa de datos. Cada mecanismo aborda una vulnerabilidad estructural específica, garantizando la confidencialidad de los datos personales, la mitigación contra la suplantación de identidad y la auditabilidad inmutable de las operaciones.

A continuación, la tabla sintetiza los controles técnicos desarrollados, su ubicación en la arquitectura y su relación con los riesgos mitigados:

Tabla 11. Relación de controles implementados, ubicación y mitigación de riesgos

Control Técnico	Componente / Ubicación	Descripción Técnica	Relación con el Riesgo Mitigado
Autenticación Criptográfica y Mitigación Anti-Replay (RT-01 / RQ-05)	src/lib/qr.ts y tabla UsedNonce en PostgreSQL	Generación y verificación de tokens efímeros firmados con HMAC-SHA256 ($TTL \leq 5$ min). Persistencia atómica del claim jti como clave primaria para asegurar el consumo de un solo uso.	Neutraliza Spoofing y ataques de repetición (replay attacks) mediante capturas visuales de códigos QR.
Control de Acceso Granular y Anti-BOLA (RT-02 / RQ-06)	src/proxy.ts (Next.js Request Interceptor)	Interceptor perimetral que inspecciona claims de rol (USER, GUARD, ADMIN, SISTEMA_LPR) y valida en el servidor la titularidad de los recursos solicitados.	Mitiga Elevation of Privilege y vulnerabilidades OWASP API1 (BOLA) y API5 (BFLA).
Minimización de Datos en Caseta (RT-03 / RQ-03)	PWA Guardia (Focus Mode) y endpoint /api/access/verify-qr	Poda de atributos en el payload devuelto a portería, restringiendo la respuesta a una tupla operativa binaria (autorizado, nombreApellido, patenteEnmascarada).	Previene Information Disclosure y perfilamiento indebido en caseta (Ley N° 21.719).
Seudonimización Integral y Búsqueda Ciega (RT-04 / RQ-10)	src/lib/crypto.ts, src/lib/masking.ts y esquema Prisma	Sustitución de claves naturales por UUID v4 en conductores, guardias y administradores. Cifrado AES-256-GCM para atributos sensibles e índice ciego determinista (HMAC-SHA256 con sal fija) para búsquedas directas.	Elimina la exfiltración masiva de identidades civiles y perfiles de movilidad ante volcados no autorizados de la base de datos.
Depuración Programada de Bitácoras (RT-05 / RQ-10)	src/lib/pruning.ts y endpoint /api/admin/pruning	Rutina transaccional para la expurgación de nonces caducados y bitácoras de acceso que superen el periodo de retención legal (≥ 5 $años$).	Evita el almacenamiento indefinido de datos personales, cumpliendo con el principio de

			limitación del plazo de conservación.
Bitácoras Inmutables Encadenadas (RT-06 / RQ-04)	src/lib/audit-chain.ts y modelo SecurityAuditLog	Encadenamiento criptográfico estricto $H_n = HMAC - SHA256_{k_{audit}}(D_n \parallel H_{n-1})$ gobernado por una clave externa segregada. Triggers de base de datos prohíben mutaciones (UPDATE/DELETE).	Impide Tampering y Repudiation de infracciones cursadas y accesos registrados por parte de usuarios privilegiados.
Rate Limiting por Sesión y Mitigación CAPTCHA (RT-07 / RQ-01 / RQ-07)	src/lib/rate-limit.ts, src/lib/captcha.ts y src/proxy.ts	Limitación de tasa discriminada exclusivamente por sessionId. Activación de desafío interactivo (CAPTCHA matemático efímero) al segundo intento fallido consecutivo en la sesión.	Neutraliza ataques de fuerza bruta y Denial of Service sin afectar a otros usuarios concurrentes bajo la misma IP institucional (NAT).
Compuertas de Seguridad DevSecOps (RT-09 / RQ-09)	.github/workflows/ci.yml y scripts/security-audit.mjs	Automatización de análisis estático (SAST con tipado Zod y linter), análisis de composición de software (SCA) y detección de secretos expuestos.	Bloquea la introducción de dependencias vulnerables (CVEs) o credenciales embebidas antes del despliegue

4.1.3 Integración con el sistema general

La solución de ciberseguridad no opera como un módulo periférico aislado, sino que se acopla transversalmente en el flujo de procesamiento de peticiones de S.I.G.T.E., vinculando la capa perimetral, la lógica del servidor y el repositorio relacional mediante cinco mecanismos de integración clave:

Intercepción Perimetral Unificada (src/proxy.ts)

Implementado bajo la convención de middleware de Next.js, actúa como la compuerta de entrada a la DMZ. Para cada solicitud entrante, el middleware resuelve el identificador unívoco de sesión (sessionId) a partir de la cabecera x-session-id, la cookie dedicada sigte_session_id o el hash del token de autorización. Si la sesión acumula dos fallos consecutivos, intercepta la ejecución exigiendo la resolución previa del CAPTCHA antes de permitir que la petición alcance los endpoints de la API. Superada esta barrera, evalúa la política RBAC contrastando los claims del usuario con los privilegios exigidos por la ruta solicitada.

Acoplamiento con la Capa de Persistencia (Prisma ORM & PostgreSQL)

Los servicios criptográficos interactúan de forma transparente con la base de datos relacional. En los modelos de datos (User, Vehicle, UsedNonce, SecurityAuditLog), los atributos se gestionan desacoplados:

Al registrar una placa patente, el sistema computa el hash determinista indexable mediante pseudonymizePersonalIdentifier(plate) y cifra el dato real con encryptSensitiveData(plate) antes de la persistencia.

En la verificación anti-replay, la inserción del nonce jti se realiza de manera transaccional sobre la tabla UsedNonce, garantizando que cualquier intento de colisión sea bloqueado a nivel de motor de base de datos mediante la restricción de clave primaria (PRIMARY KEY).

Integración del Flujo de Auditoría Inmutable

Cada vez que se procesa un evento de acceso (/api/access/verify-qr o /api/access/verify-lpr) o se cursa una boleta de infracción en terreno, la lógica de negocio invoca el módulo audit-chain.ts. Este obtiene atómicamente el hash del último bloque registrado (H_{n-1}), genera el payload serializado canónicamente (D_n), calcula el nuevo sello H_n empleando la clave segregada K_{audit} (alojada en variables de entorno y aislada del motor de base de datos) y almacena el registro en modo append-only.

Integración con Dispositivos Perimetrales y Nodos LPR

Los nodos comerciales de visión artificial se integran mediante el endpoint seguro /api/access/verify-lpr utilizando autenticación basada en clave de servicio (X-LPR-API-Key) sobre enlaces cifrados con TLS 1.3. La búsqueda de la placa capturada se ejecuta en tiempo O(1) contrastando directamente el Blind Index calculado en memoria contra el índice hash de la base de datos, logrando resolver el veredicto en menos de 5 ms sin descifrar masivamente tablas en reposo.

Matriz de Endpoints y Reglas de Seguridad

La tabla a continuación detalla la superficie de exposición del sistema, los métodos HTTP expuestos, los roles autorizados y las restricciones de seguridad asociadas:

Tabla 12. Matriz de integración de endpoints, métodos y reglas de seguridad aplicadas

Endpoint del Sistema	Método	Rol Mínimo Requerido	Controles y Reglas de Seguridad Activas	Payload Minimizado / Respuesta
/api/auth/captcha	GET	Público	Emisión de desafío matemático firmado mediante HMAC-SHA256 con ventana de validez $TTL = 5 \text{ min}$.	{ success: true, challenge: { challengeId, question, token } }
/api/auth/captcha	POST	Público	Validación atómica de respuesta matemática y desbloqueo de la sesión interceptada.	{ success: true, message: string, captchaRequired: false }
/api/auth/login	POST	Público	Rate limiting por sessionId, activación de CAPTCHA al 2° fallo consecutivo,	{ id: UUID, email: string, name: string, role: Role, token: string }

			bcryptjs (coste salt = 10).	
/api/auth/qr/generate	POST	USER	Rate limiting de generación (10 req/min por sesión), autenticación JWT de sesión, verificación Anti-BOLA.	{ token: string, expires_at: ISO8601, jti: UUID }
/api/access/verify-qr	POST	GUARD	Rate limiting de caseta (60 req/min por sesión), consumo atómico anti-replay en UsedNonce, verificación HMAC ($TTL \leq 5$ min) y sellado en cadena inmutable.	{ autorizado: boolean, nombreApellido: string, patenteEnmascarada: string, veredicto: "ALLOW" | "DENY" }
/api/access/verify-lpr	POST	SISTEMA_LPR	Cabecera X-LPR-API-Key, consulta determinista O(1) sobre Blind Index, TLS 1.3 estricto y sellado de bitácora.	{ veredicto: "ALLOW" | "DENY", gate_id: string, autorizado: boolean, patenteEnmascarada: string }
/api/access/lookup	GET	GUARD / ADMIN	Rate limiting por sesión, RBAC, consulta vía Blind Index. Poda diferencial: si el rol es GUARD, suprime RUT y correo.	Guardia: { vehicle: { id, plateMasked, owner: { name } } } (0% RUT/correo)
/api/admin/audit/verify	GET	ADMIN	Evaluación algorítmica de integridad forense verificando la continuidad matemática H_n de toda la bitácora.	{ valid: true, count: number, lastHash: string }
/api/admin/pruning	POST	ADMIN	RBAC administrativo, purga transaccional de bitácoras ≥ 5 $años$ y nonces caducados con registro de auditoría.	{ purgedAccessLogs: number, purgedNonces: number, dryRun: boolean }

4.2 Codificación, configuración y desarrollo

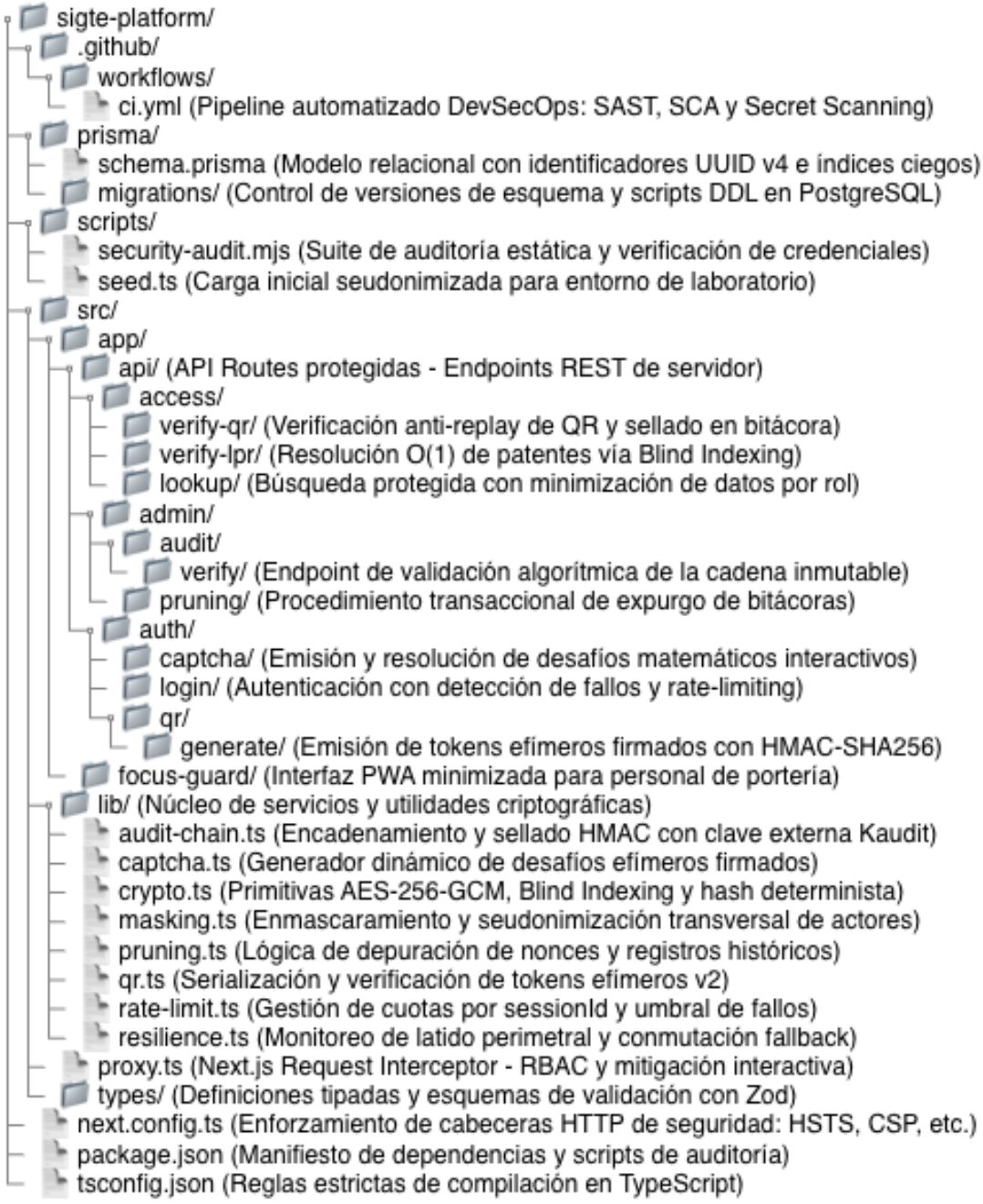
La materialización técnica del marco integral de ciberseguridad se desarrolló sobre el repositorio unificado de la plataforma S.I.G.T.E., utilizando como base el framework Next.js bajo entorno Node.js y el motor de persistencia relacional PostgreSQL desplegado de forma contenerizada. Para salvaguardar la robustez operativa y la mantenibilidad de la solución, la ingeniería de software se articuló bajo el

paradigma de Security by Design, integrando validaciones tipadas en tiempo de compilación y desacoplando la gestión criptográfica en módulos utilitarios especializados.

4.2.1 Estructura de directorios y módulos principales

El proyecto organiza sus componentes defensivos segregando la capa de presentación perimetral, la lógica de negocio en endpoints de API, los servicios criptográficos transversales y las definiciones de infraestructura como código. La estructura representativa del repositorio se describe a continuación:

Figura 3. Estructura de directorios y módulos principales



4.2.2 Control de versiones y estrategia de ramas

La evolución del código fuente se gobernó mediante Git y la plataforma GitHub, adoptando una estrategia simplificada basada en Trunk-Based Development combinada con ramas de características (feature branches) protegidas. Las modificaciones orientadas a ciberseguridad se integraron bajo las siguientes directrices:

- **Ramas de desarrollo específicas:** Cada control técnico se codificó en ramas dedicadas (por ejemplo: feature/session-rate-limit, feature/pseudonymization-all-roles, feature/tamper-proof-audit).
- **Compuertas obligatorias para fusión:** Las solicitudes de extracción (Pull Requests) hacia la rama principal requerían la aprobación obligatoria de las compuertas automatizadas de integración continua. La detección de errores tipados, vulnerabilidades conocidas en dependencias o fallos en las 84 pruebas unitarias de seguridad bloqueaba automáticamente la integración.
- **Historial atómico y trazable:** Se utilizó la técnica de Squash and Merge para preservar un registro lineal, ordenado y auditable de los cambios aplicados en la arquitectura.

4.2.3 Manejo de secretos y variables de entorno

En estricta observancia de los lineamientos del departamento y las buenas prácticas de DevSecOps, ninguna credencial de acceso, clave criptográfica ni parámetro institucional sensible se incluyó en el código fuente ni en el historial del repositorio. La gestión de la configuración sensible se resolvió desacoplando el entorno operativo mediante variables de entorno segregadas e inyectadas dinámicamente en tiempo de ejecución:

Código 4.1: Variables de entorno

```
# Entorno de Laboratorio y Persistencia
DATABASE_URL="postgresql://sigte_user:********@127.0.0.1:5432/sigte_db?sslmode=prefer"
NODE_ENV="development"

# Secretos Criptográficos Perimetrales y de Sesión
NEXTAUTH_SECRET="f6c8d7e0a2b1...[256-bit entropy]..."
JWT_SIGNING_SECRET="a1b2c3d4e5f6...[256-bit entropy]..."
LPR_SYSTEM_API_KEY="sigte_lpr_secret_...[clave de servicio nodo perimetral]..."

# Gobernanza y Privacidad (Aislamiento de Claves)
AES_ENCRYPTION_KEY="0123456789abcdef...[32-byte key para AES-256-GCM]..."
BLIND_INDEX_SALT="usm_sigte_salt_blind_index_2026_fixed"

# Auditoría Forense y No Repudio (Aislamiento fuera de BD)
K_AUDIT_SECRET="sigte_audit_tamper_proof_hmac_k_audit_segregated_key_2026"
```

El módulo src/lib/crypto.ts verifica de manera determinista la existencia de estos secretos al iniciar el proceso; si alguna de las claves requeridas no está declarada o posee una entropía menor a la esperada, la inicialización del sistema se interrumpe preventivamente.

4.2.4 Implementación técnica de los módulos críticos

Conforme a las recomendaciones metodológicas, en esta subsección no se incorpora código completo, sino fragmentos breves y representativos que justifican las decisiones técnicas adoptadas.

Resolución de sesión y mitigación interactiva con CAPTCHA (src/proxy.ts y src/lib/rate-limit.ts)

Para solventar la restricción del entorno universitario, donde múltiples usuarios y dispositivos comparten la misma dirección IP pública institucional mediante NAT perimetral, el interceptor resuelve la identidad de la sesión antes de aplicar cualquier límite de tasa. Si una sesión alcanza el umbral de fallos consecutivos, el sistema intercepta las peticiones subsecuentes exigiendo la resolución de un desafío dinámico:

Código 4.2: Resolución de sesiones

```
// Fragmento representativo: src/proxy.ts
const sessionId = resolveSessionId(request);

// Evaluación del estado interactivo de la sesión específica
if (isCaptchaRequiredForSession(sessionId)) {
  const solved = await verifySessionCaptchaResponse(request, sessionId);
  if (!solved) {
    return NextResponse.json(
      {
        error: "Se requiere validación de CAPTCHA tras 2 intentos fallidos consecutivos en la sesión",
        code: "CAPTCHA_REQUIRED",
        captchaRequired: true,
        sessionId,
      },
      {
        status: 403,
        headers: { "X-Captcha-Required": "true" }
      }
    );
  }
  // Al validar exitosamente el CAPTCHA, se restablece el contador de la sesión
  resetSessionFailures(sessionId);
}
```

Este desacoplamiento garantiza que un atacante ejecutando fuerza bruta sobre una sesión en la red Wi-Fi universitaria sea bloqueado de inmediato sin degradar la disponibilidad ni afectar las solicitudes de otros usuarios que operan legítimamente desde la misma dirección IP.

Seudonimización en reposo y búsqueda ciega determinista (src/lib/crypto.ts)

Para resguardar las placas patentes y los identificadores civiles (RUT) en PostgreSQL sin comprometer la capacidad del nodo LPR de consultar registros en tiempo constante, se implementó un esquema que combina el cifrado simétrico autenticado (AES-256-GCM) con un índice ciego determinista (Blind Index) basado en HMAC-SHA256:

Código 4.3: Seudonimización y búsqueda ciega

```
// Fragmento representativo: src/lib/crypto.ts
export function encryptSensitiveData(plaintext: string): { cipherText: string; iv: string; tag: string } {
  const iv = crypto.randomBytes(12); // IV único y no repetible por registro
  const cipher = crypto.createCipheriv("aes-256-gcm", Buffer.from(AES_KEY, "hex"), iv);
  const encrypted = Buffer.concat([cipher.update(plaintext, "utf8"), cipher.final()]);
  const tag = cipher.getAuthTag();
  return {
    cipherText: encrypted.toString("hex"),
    iv: iv.toString("hex"),
    tag: tag.toString("hex"),
  };
}

export function computeBlindIndex(identifier: string): string {
  const normalized = identifier.trim().toUpperCase().replace(/[^A-Z0-9]/g, "");
  return crypto
    .createHmac("sha256", Buffer.from(BLIND_INDEX_SALT, "utf8"))
    .update(normalized)
    .digest("hex");
}
```

La normalización previa asegura que las discrepancias en formato (como guiones o espacios) no afecten la coincidencia matemática del hash, permitiendo a las API Routes ejecutar consultas relacionales mediante coincidencia exacta (WHERE plateBlindIndex = :hash) en menos de 5 ms sin exponer la patente en texto claro en disco ni en volcados (dumps).

Integridad forense y encadenamiento criptográfico (src/lib/audit-chain.ts)

El registro de accesos y sanciones implementa un mecanismo de sellado determinista donde cada registro n concatena la carga útil del evento (D_n) con el hash del evento precedente (H_{n-1}):

Código 4.4: Encadenamiento criptográfico

```
// Fragmento representativo: src/lib/audit-chain.ts
export function calculateNextAuditHash(payload: AuditEventPayload, previousHash: string): string {
  // Serialización canónica determinista para garantizar estabilidad de orden de atributos
  const serializedData = canonicalJsonStringify(payload);
  const dataToSign = `${serializedData}|${previousHash}`;

  return crypto
    .createHmac("sha256", Buffer.from(process.env.K_AUDIT_SECRET!, "utf8"))
    .update(dataToSign)
    .digest("hex");
}
```

Dado que la clave K_{audit} reside exclusivamente en la memoria del servicio de aplicación y está aislada de la base de datos, un actor con privilegios administrativos directos en PostgreSQL no puede alterar

retrospectivamente una tupla histórica sin romper de forma matemática la secuencia de hashes, impidiendo el repudio o la manipulación de evidencias ante auditorías administrativas o judiciales.

4.2.5 Despliegue en laboratorio y gestión de dependencias

El entorno de ejecución experimental se aprovisionó de manera aislada utilizando contenedores Docker para garantizar la reproducibilidad de los resultados:

- **Entorno de persistencia:** Se desplegó una instancia local del motor PostgreSQL mediante la imagen oficial postgres:16-alpine, exponiendo el puerto estándar 5432 mapeado internamente hacia un volumen seguro. La sincronización del modelo de datos y la creación de restricciones de integridad atómica se ejecutaron mediante Prisma CLI (pnpm prisma migrate deploy).
- **Gestión de paquetes y minimización de superficie:** La gestión de dependencias se centralizó a través de pnpm, priorizando bibliotecas especializadas y con mínimo árbol de subdependencias: @prisma/client para persistencia relacional tipada, zod para validación estricta de esquemas en servidor, jose y funciones criptográficas nativas de Node.js (node:crypto) para primitivas HMAC, AES-GCM y JWT.
- **Endurecimiento de cabeceras HTTP:** A nivel de servidor web, el archivo next.config.ts se parametrizó para inyectar cabeceras de respuesta defensivas en cada transacción: Strict-Transport-Security (max-age=63072000; includeSubDomains; preload), X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin y directrices restrictivas de Content-Security-Policy (CSP).

4.3 Integración con otros componentes o herramientas

El marco de ciberseguridad y gobernanza diseñado para S.I.G.T.E. no funciona como un monolito autosuficiente, sino que interactúa estrechamente con un ecosistema de herramientas externas, servicios en la nube y componentes de automatización. Estas integraciones operan como mecanismos de soporte para garantizar la inspección continua de código, la trazabilidad de eventos de seguridad, el aprovisionamiento reproducible de infraestructura y la comunicación protegida entre subsistemas distribuidos.

4.3.1 Compuertas automatizadas en el pipeline de CI/CD (GitHub Actions)

La integración continua de la plataforma incorpora compuertas automatizadas de seguridad (Quality Gates) mediante flujos de trabajo orquestados en GitHub Actions (.github/workflows/ci.yml). En lugar de depender de revisiones manuales periódicas, cada evento de inserción de código (push) o solicitud de extracción (pull request) desencadena una secuencia de verificación dividida en tres etapas preventivas:

- **Análisis Estático de Seguridad de Aplicaciones (SAST):** Se ejecuta una validación rigurosa de tipos y buenas prácticas con TypeScript (tsc --noEmit) y ESLint, complementada con el análisis de esquemas tipados mediante Zod. Esta verificación previene la introducción de desbordamientos de tipos, omisiones de validación en parámetros de entrada y fallos lógicos a nivel de servidor.
- **Análisis de Composición de Software (SCA):** Mediante la invocación programada del motor de auditoría del gestor de paquetes (pnpm audit), el pipeline examina de forma exhaustiva el árbol completo de dependencias de terceros. El flujo detiene automáticamente la compilación si

detecta cualquier librería afectada por vulnerabilidades públicas conocidas (CVEs) clasificadas con severidad Alta o Crítica, satisfaciendo el requerimiento RT-09 / RQ-09.

- **Escaneo Automatizado de Credenciales y Secretos:** A través del script scripts/security-audit.mjs, se inspecciona el árbol del repositorio en busca de patrones de cadenas de alta entropía, llaves privadas, certificados o credenciales hardcodeadas antes de permitir la fusión hacia la rama principal, impidiendo la fuga de información sensible.

4.3.2 Orquestación y persistencia relacional aislada (Docker & PostgreSQL)

Para asegurar la paridad técnica entre el entorno de desarrollo y el banco de pruebas de laboratorio sin depender de infraestructura compartida ni exponer bases de datos productivas, la persistencia se apoya en contenedores Docker y el ORM Prisma:

- **Contenerización con Docker:** El motor de base de datos se despliega de forma local y aislada mediante la imagen oficial postgres:16-alpine. Esta segmentación permite confinar la persistencia a una red virtual interna, restringiendo las conexiones entrantes exclusivamente a la interfaz de loopback (127.0.0.1) y protegiendo los puertos frente a accesos no autorizados desde redes locales adyacentes.
- **Gestión de Datos con Prisma ORM:** El esquema relacional se sincroniza de forma determinista mediante Prisma CLI (prisma migrate deploy). El cliente de Prisma abstrae el acceso al motor de datos aplicando consultas parametrizadas por defecto, lo que neutraliza de origen los vectores de inyección SQL (SQLi). Asimismo, el esquema modela las restricciones de unicidad sobre la tabla UsedNonce y los campos de indexación ciega (plateBlindIndex), permitiendo que el motor relacional ejecute el control anti-replay y la búsqueda de patentes de forma atómica y consistente.

4.3.3 Intermediación con nodos perimetrales LPR y pasarelas de hardware

La capa de servicios en Next.js se acopla a las cámaras y dispositivos de borde comercial (nodos de reconocimiento de matrículas LPR) mediante una interfaz de programación de aplicaciones desacoplada:

- **Autenticación de Servicio Perimetral:** Debido a que las cámaras LPR en caseta operan de forma autónoma sin una sesión interactiva de usuario, la autorización se canaliza a través del endpoint /api/access/verify-lpr mediante la cabecera dedicada X-LPR-API-Key. Esta credencial de máquina a máquina (M2M) cuenta con una alta entropía y se valida en tiempo constante dentro del middleware de la API.
- **Canal Seguro y Resiliencia Perimetral:** Toda la comunicación se encripta mediante HTTPS forzando el protocolo TLS 1.3 con suites criptográficas robustas (RT-08). Paralelamente, el módulo de resiliencia (src/lib/resilience.ts) supervisa de manera continua el latido (heartbeat) del nodo LPR; en caso de degradación de red o falla física en la cámara, el sistema señaliza automáticamente la conmutación hacia el método secundario de contingencia (lectura de QR dinámico o cédula de identidad por el guardia) en menos de 5 segundos, garantizando la continuidad operativa estipulada en el requerimiento RQ-08.

4.3.4 Registro estructurado de eventos y telemetría forense (SecurityEvent)

La trazabilidad de incidentes y eventos operacionales se gestiona mediante un componente de auditoría interno desacoplado de la visualización ordinaria:

- **Estructuración y Minimización de Logs:** Los eventos anómalos (activaciones del desafío CAPTCHA tras 2 fallos consecutivos, intentos de retransmisión de nonces, errores de autenticación y accesos denegados por RBAC) se registran de forma estructurada en la entidad SecurityEvent.
- **Preservación de la Privacidad en Telemetría:** En cumplimiento con los principios de minimización y seudonimización de la Ley N° 21.719, el módulo de logging no registra datos personales en texto claro (PII). Como resguardo técnico, el identificador de sesión se procesa a través de la función pseudonymizeSessionId(sessionId) y la identidad del operador se transforma en un hash irreversible (actorHash), almacenando únicamente marcas de tiempo ISO 8601, direcciones IP de origen y códigos de error normalizados. Esto asegura una cobertura de eventos de seguridad superior al 95% (RQ-07) sin comprometer la privacidad de los usuarios ante eventuales revisiones forenses.

4.4 Consideraciones éticas y de autorización

El desarrollo, implementación y evaluación experimental del marco de ciberseguridad para S.I.G.T.E. involucra el tratamiento de identificadores vehiculares, registros de tránsito y credenciales de acceso. Por este motivo, la ejecución del proyecto se estructuró bajo estrictos principios éticos, de autorización explícita y de minimización del impacto operacional, garantizando que ninguna actividad técnica vulnerara la privacidad de la comunidad universitaria ni la estabilidad de la infraestructura institucional.

4.4.1 Entorno de pruebas controlado y autorización de evaluación

En estricta observancia de los lineamientos del departamento y la delimitación del alcance técnico:

- **Aislamiento de la infraestructura productiva:** Todas las pruebas de concepto (PoC), simulaciones de inyección de tokens duplicados (replay attacks), validaciones de control de acceso (RBAC) y pruebas de carga concurrente se ejecutaron de manera exclusiva en un entorno de laboratorio local, cerrado y controlado. En ningún momento se realizaron pruebas ofensivas, escaneos de puertos ni inyecciones contra la infraestructura en producción de la Universidad Técnica Federico Santa María ni contra las redes institucionales activas de la sede Viña del Mar.
- **Prohibición de intrusión física o explotación perimetral:** Las evaluaciones no contemplaron ataques de penetración física, interferencias por radiofrecuencia a las barreras electromecánicas, interceptación no autorizada sobre el cableado de red de las casetas ni técnicas de ingeniería social dirigidas al personal de vigilancia o a los conductores. Los vectores evaluados se limitaron estrictamente a las interfaces lógicas de aplicación (APIs), los esquemas de sesión, las restricciones criptográficas y la capa de persistencia relacional en contenedores aislados.

4.4.2 Tratamiento de datos sensibles, anonimización y datos sintéticos

Dado que el sistema procesa datos personales que permiten inferir rutinas de movilidad y permanencia, el tratamiento durante las fases de diseño y experimentación se apegó a las directrices de la Ley N° 21.719 sobre Protección de Datos Personales:

- **Uso de datos sintéticos y simulados:** Durante la totalidad de la fase de pruebas experimentales, no se utilizaron registros de identidad civil reales ni historiales efectivos de conductores del campus. La población de prueba en la base de datos de laboratorio se construyó mediante un script determinista de siembra (scripts/seed.ts), el cual generó perfiles ficticios para todos los roles (USER, GUARD, ADMIN) combinados con placas patentes ficticias estructuradas según el formato vehicular chileno.
- **Seudonimización transversal por diseño:** En cumplimiento del principio de Privacidad por Diseño (PbD), los datos generados se sometieron a las funciones de disociación y enmascaramiento implementadas en src/lib/masking.ts y src/lib/crypto.ts. Las tablas operativas y bitácoras asociaron a los usuarios únicamente mediante identificadores opacos (UUID v4), sustituyendo cualquier correlación directa con RUT, teléfonos o correos electrónicos.
- **Protección de volcados y evidencias:** Para las comprobaciones de laboratorio orientadas a verificar la ininteligibilidad de los respaldos (dumps de PostgreSQL), se constató la ausencia de identificadores civiles en texto claro, corroborando que tanto las placas patentes cifradas con AES-256-GCM como sus índices ciegos (Blind Index) son computacionalmente irreversibles sin las claves maestras institucionales.

4.4.3 Principio de proporcionalidad y no vigilancia indebida

Uno de los principales dilemas éticos identificados en la plataforma preliminar correspondía al riesgo de perfilamiento y vigilancia masiva derivado de la correlación de patentes con las bitácoras georreferenciadas:

- **Poda de visibilidad en caseta (Focus Mode):** Se implementó una política estricta de minimización de datos en la interfaz del guardia en terreno. El operador perimetral solo recibe un veredicto binario (autorizado: booleano) acompañado del nombre operativo y la placa enmascarada, suprimiéndose atributos sensibles (RUT, carrera, historial de infracciones o correo institucional) que pudieran dar pie a discriminaciones arbitrarias o exposición indebida en ventanilla.
- **Limitación de la conservación y olvido institucional:** La incorporación de directrices y procedimientos de depuración programada (data pruning) en el módulo src/lib/pruning.ts garantiza que las bitácoras históricas no se conserven por más de 3 años, impidiendo la construcción de historiales permanentes de movilidad sobre los miembros de la comunidad universitaria y asegurando el debido cumplimiento normativo frente a la futura Agencia de Protección de Datos Personales.

5. Resultados

5.1 Estrategia de pruebas y validación

5.2 Métricas y resultados obtenidos

5.3 Resolución de hallazgos, bugs y optimización

5.4 Limitaciones de la validación

6. Conclusiones

7. Referencias

8. Anexos